**INTERNATIONAL CYBERSECURITY AND DIGITAL FORENSICS ACADEMY**

GRC103 Risk Assessment and Management Techniques

Module 3: Risk Treatment Strategies

# Technical Risk Treatment Lab Report

Implementing and Validating Controls on a Local Linux Server – Northbridge Services (fictional organisation)

| Item | Detail |
|---|---|
| Name | Oluwatosin Olajubu |
| Registration number | C11/26/CGRCE/17602 |
| Role in scenario | GRC analyst and technical control implementer |
| Report date | 6 November 2026 |
| Lab systems | Ubuntu Server 26.04.1 LTS (192.168.164.131) and Kali Linux 2025.4 (192.168.164.128 at first check, 192.168.164.132 from baseline) on a VMware host-only network |
| Data used | Fictional / dummy data only. No real records, no passwords, no private keys, no VM disk images are included. |

**Evidence legend used throughout this report**

| Label | Meaning |
|---|---|
| MEASURED | Result produced by a command or test in my lab, with an evidence file or screenshot. |
| SIMULATED | Approval, sign-off or role action that is part of the exercise only. No real approval took place. |
| ASSUMPTION | Fictional figure or judgement supplied by the brief or by me. Not established by a lab test. |

# 1. Management summary

Northbridge Services' internal document server exposed two things it did not need to: a legacy web endpoint on port 8080 and a directory of records that anyone on the network could list and download. I built a two-machine laboratory, measured the exposure, scored four risks, and then treated them with avoidance, mitigation, transfer and acceptance decisions while keeping the approved web portal on port 80 available.

### What was measured

- **Baseline:** from Kali, ports 80 and 8080 were both open. The Nginx root listing showed the archive and public folders, the archive listing was readable, and the dummy record was downloadable with HTTP 200 and no authentication. The legacy service answered on 8080 (Python SimpleHTTP/0.6). [Measured]
- **Avoidance (R1):** the legacy service was disabled. Afterwards Nmap showed 8080 closed, curl failed to connect (exit code 7), and the Ubuntu socket listing no longer showed a listener on 8080. Port 80 stayed open. [Measured]
- **Archive hardening (R2):** the archive was moved out of the web root to /srv/grc-private (root-only, mode drwx------), autoindex was switched off and an explicit deny rule was added. From Kali, /public/ still returned 200 while /archive/ and /archive/dummy-records.txt returned 403 (both were 200 at baseline). [Measured]
- **Firewall (R3):** UFW was enabled with default deny for incoming traffic and one allow rule, 80/tcp from 192.168.164.132 (Kali). The approved source still reached the portal. Nmap then showed 22 and 8080 as filtered, and the UFW log recorded the blocked packets. [Measured]
- **Logs:** the Nginx access log shows the archive changing from 200 to 403 for the same source address, and the UFW log separately records blocked traffic that never reached Nginx. [Measured]
- **Backup and recovery (R4):** the public folder was backed up, its SHA-256 recorded, index.html deleted (Kali then received 403), the file restored from the backup, the hash check returned OK, and /public/ returned 200 with the same size, Last-Modified and ETag as before. Observed recovery was about 11 minutes by manual steps (single small file, lab only). [Measured]

### Limits of the evidence

The blocked-request evidence comes from the Nmap scan and the UFW log (ports 22 and 8080, from Kali and from the Windows host), while the portal on port 80 was tested from the approved source. The rollback procedure for CR-001 is documented but was not executed. The recovery time was recorded by manual steps and is approximate. These limits are described in Section 13.

### What management is asked to decide

| Decision | Recommendation |
|---|---|
| Treatment package (first year) | Approve option A (hardening, $150) and option B (managed backup, $360): **$510 first-year cost** [Assumption: fictional prices]. |
| TLS (option C, $100) | Defer. Accept plain HTTP for a maximum of 14 days (to 20 Nov 2026) on the isolated network with dummy data only. TLS becomes mandatory before any real data or external connectivity. [Simulated approval] |
| Backup value case | Illustrative annual loss expectancy falls from $1,000 to $200; first-year net benefit of B is $440 [Assumption only, see Section 11]. |
| Residual risk | R1 Low (4). R2, R3 and R4 are Medium (5, 5 and 9) based on the tests in this report. No risk is rated zero: the local backup shares a host with the data, source-address filtering is not authentication, and the retired service could be re-enabled. |

## 2. Scope, environment and method

All work was done on my own computer using two virtual machines in VMware Workstation. Only fictional files were used. The network was a host-only network (192.168.164.0/24). A temporary NAT adapter was used on the Ubuntu VM to download packages.

| Component | Detail (measured from screenshots) |
|---|---|
| Ubuntu server | Ubuntu 26.04.1 LTS (kernel 7.0.0-42-generic), 4 GB RAM, 2 vCPUs, 20 GB disk, host-only adapter. Interface ens33 = 192.168.164.131/24 (earlier 192.168.233.131 while on NAT). |
| Kali Linux | Kali 2025.4 (VMware build). At the first connectivity check: eth1 = 192.168.164.128/24 (host-only) and eth0 = 192.168.233.128/24 (NAT). From the baseline onward the Nginx log shows Kali as 192.168.164.132 (DHCP lease change); after the restart the host-only adapter appears as eth0 and eth1 is no longer present. |
| Windows host | 192.168.164.1 on the host-only network. Used for one SSH session (see Section 13). |
| Software versions | nginx 1.28.3, ufw 0.36.2, Python 3.14.4, curl 8.18.0 (Ubuntu); Nmap 7.95 (Kali). |
| Connectivity checks | Ubuntu to Internet via NAT before isolation (ping ubuntu.com, 0% loss). Kali to Ubuntu on host-only: 4/4 replies, 0.816–2.260 ms. Ubuntu to Kali: 4/4 replies, 0.647–1.048 ms. |
| Time zones | Ubuntu logs are in UTC. Kali shell timestamps are EST (UTC−5), so 15:05 EST = 20:05 UTC. HTTP Date headers are GMT. |

### 2.1 Deviations from the brief

| Deviation | Effect and handling |
|---|---|
| Ubuntu 26.04.1 LTS used instead of 24.04 LTS | Same tooling (nginx, ufw, systemd) was available. Documented here; no effect on results. |
| 20 GB disk and 4 GB RAM instead of 25 GB disk | Disk usage was 31–34% of 9.75 GB, sufficient for the lab. |
| One configuration session over SSH | My keyboard's curly-bracket key failed, which blocked typing the Nginx server block at the console. I used SSH from the Windows host over the host-only network for that one task. All firewall changes are planned for the VM console as required. |
| Kali address changed by DHCP | The approved source in UFW and all later tests use 192.168.164.132. Screenshots from the first connectivity check show .128. See Section 13. |

# 3. Baseline environment and evidence (Steps 1 to 4)

## 3.1 Build summary

**Step 1 – Prepare Ubuntu.** Packages nginx, ufw, python3 and curl were installed while NAT was available. Versions confirmed with nginx -v, ufw version, python3 --version and curl --version. openssh-server was later installed for the SSH session in Section 13. Ubuntu was then moved to the host-only adapter and ip -br addr confirmed 192.168.164.131/24. [Measured]

**Step 2 – Fictional content and legacy service.** Three directories were created (root-owned, mode 755): /var/www/grc-lab/public, /var/www/grc-lab/archive and /srv/grc-legacy. Content created:

| File | Content | Size |
|---|---|---|
| /var/www/grc-lab/public/index.html | Approved internal portal | 25 bytes |
| /var/www/grc-lab/archive/dummy-records.txt | DUMMY RECORD A001 - training only | 34 bytes |
| /srv/grc-legacy/index.html | Legacy training endpoint | 25 bytes |

The legacy service was defined in /etc/systemd/system/grc-legacy.service, running python3 -m http.server 8080 --bind 0.0.0.0 as user www-data from /srv/grc-legacy. The first attempt to enable it failed with "Invalid unit name =multi-user.target" because I had typed WantedBy== with two equals signs. After correcting the typo, running daemon-reload and enable --now succeeded and systemctl status showed the unit enabled and active (running) since 14:51:12 UTC (main PID 3743). [Measured]

**Step 3 – Lab web service.** A server block was created in /etc/nginx/sites-available/grc-lab (listen 80, root /var/www/grc-lab, access log grc_access.log in combined format, error log grc_error.log, autoindex on). It was enabled by symlink, the default site was removed, nginx -t reported "syntax is ok / test is successful", and Nginx was reloaded. systemctl status nginx showed active (running) since 13:23:29 UTC. [Measured]

```
server {
    listen 80;
    server_name _;
    root /var/www/grc-lab;
    access_log /var/log/nginx/grc_access.log combined;
    error_log /var/log/nginx/grc_error.log;
    location / { autoindex on; }
}
```

Screenshots: Figures 1 to 27 (Appendix A) show the package installs, addresses, content creation, legacy unit, Nginx configuration and SSH session.

## 3.2 Baseline collection from Kali (Step 4)

SERVER_IP was set to 192.168.164.131 and all output was saved in ~/grc-treatment-evidence on Kali.

| ID | Test (from 192.168.164.132) | Result | Time | Evidence file |
|---|---|---|---|---|
| T01 | nmap -sT -p 80,8080 | 80/tcp open http; 8080/tcp open http-proxy; host up (0.0018 s latency) | 15:05 EST | baseline-ports.txt (413 B) |
| T02 | curl -i http://SERVER_IP/ | HTTP/1.1 200 OK, Server nginx/1.28.3. Index of / lists archive/ and public/ | 20:06:37 GMT | baseline-web.txt (524 B) |
| T03 | curl -i …/archive/ | HTTP/1.1 200 OK. Index of /archive/ lists dummy-records.txt (34 bytes) | 20:08:46 GMT | baseline-listing.txt (437 B) |
| T04 | curl -i …/archive/dummy-records.txt | HTTP/1.1 200 OK, text/plain, Content-Length 34, body "DUMMY RECORD A001 - training only" | 20:10:49 GMT | baseline-file.txt (280 B) |

| ID | Test (from 192.168.164.132) | Result | Time | Evidence file |
|---|---|---|---|---|
| T05 | curl -i …:8080/ | HTTP/1.0 200 OK, Server SimpleHTTP/0.6 Python/3.14.4, body “Legacy training endpoint” | 20:12:07 GMT | baseline-legacy.txt (210 B) |

On Ubuntu, sudo ss -lntp showed these listeners: sshd on 0.0.0.0:22 and [::]:22, nginx on 0.0.0.0:80, python3 on 0.0.0.0:8080 (PID 1158) and systemd-resolved on local addresses only (port 53). [Measured]

Screenshots: Figures 28 to 34 (Appendix A) show the baseline Nmap, curl and ss outputs.

### Baseline findings

- The approved web server and the unnecessary legacy service were both reachable from the network.
- Directory listing (autoindex on) let any client enumerate the archive folder.
- The archive file was retrievable directly by URL with no authentication, so the weakness is both the listing and the location of the file inside the web root.
- No effective host firewall restriction was observed: both ports answered Kali.
- Additional observation: SSH (22/tcp) was listening because I enabled it for the keyboard workaround. It was outside the Nmap scope of the brief (ports 80 and 8080) but is visible in ss. See Section 13.

# 4. Baseline risk register (Step 5)

Scoring uses the classroom scale: likelihood 1–5 × impact 1–5. Bands: 1–4 Low, 5–9 Medium, 10–16 High, 17–25 Critical. These are ordinal classroom thresholds, not monetary values or statistical probabilities. The initial scores are those given in the practical brief, and the evidence below supports them.

### 4.1 Risk descriptions

| ID | Asset | Threat event | Observed weakness | Evidence | Treatment owner |
|---|---|---|---|---|---|
| R1 | Legacy endpoint on Ubuntu server (port 8080) | Unauthorised or accidental use of an unmaintained service | Unneeded HTTP service listening on all interfaces, no owner, no authentication | T01, T05; ss -lntp (python3 on 0.0.0.0:8080) | IT Operations Manager |
| R2 | Archive records (dummy-records.txt) | Unauthorised disclosure of records | Archive inside web root, autoindex on, world-readable, no access control | T02, T03, T04 | Records Owner / Data Owner |
| R3 | Approved web server (Nginx, port 80) | Unauthorised network access or scanning | No source-based filtering; any host on the network can connect; plain HTTP | T01–T04: Kali reached all content | Network and Security Lead |
| R4 | Approved portal content (public/index.html) | Accidental deletion or corruption | Single copy, no backup, no restore procedure, no integrity baseline | Backup directory does not exist at baseline; no hash record | IT Operations Manager |

### 4.2 Scoring and existing control gaps

| ID | Likelihood | Impact | Score | Rating | Existing control gaps |
|---|---|---|---|---|---|
| R1 | 4 | 4 | 16 | High | No business justification or decommission process; listens on 0.0.0.0; no authentication; no monitoring of listening ports. |
| R2 | 4 | 5 | 20 | Critical | No authorisation control; content published by location rather than by policy; directory listing enabled; no deny rule for the archive path. |
| R3 | 3 | 5 | 15 | High | No host firewall allow-list; no default-deny; no firewall logging evidence; HTTP only; SSH also listening. |
| R4 | 3 | 4 | 12 | High | No backup, no restore test, no checksum baseline, no recovery time measurement. |

This register is saved as the baseline for comparison with the residual assessment in Section 12.

# 5. Avoidance: retire the legacy service (Step 6)

## 5.1 Change and rollback record

| Field | Entry |
|---|---|
| Change ID / date | CR-001 / 6 November 2026 |
| Proposed change | Retire the unused legacy endpoint (grc-legacy.service, port 8080). Retain the approved portal on port 80. |
| Business impact | None expected. The legacy endpoint holds only the text "Legacy training endpoint" and supports no approved workflow. The approved portal on port 80 must remain available. |
| Approval role | Head of IT Operations. SIMULATED approval for this exercise only. |
| Pre-change test | T05: legacy endpoint returns HTTP 200 on 8080; T01: ports 80 and 8080 open. |
| Post-change test | Port 8080 closed, curl to 8080 fails, no listener on 8080 in ss, port 80 still open. |
| Rollback | sudo systemctl enable --now grc-legacy, then reapply the treatment and leave the service disabled in the final state. |
| Rollback test | Procedure defined above. It was not executed in this lab; the control was left in its final disabled state. |

## 5.2 Implementation (Ubuntu)

```
sudo systemctl disable --now grc-legacy
sudo systemctl is-active grc-legacy
sudo ss -lntp
```

Results: systemd reported "Removed /etc/systemd/system/multi-user.target.wants/grc-legacy.service", is-active returned "inactive", and ss -lntp listed only 22 (sshd), 80 (nginx) and the local DNS resolver; no listener on 8080. [Measured]

## 5.3 Verification from Kali

| ID | Test | Result | Evidence file |
|---|---|---|---|
| T06 | nmap -sT -p 80,8080 (15:21 EST) | 80/tcp open http; 8080/tcp closed http-proxy | avoidance-ports.txt (418 B) |
| T07 | curl -i --connect-timeout 5 http://192.168.164.131:8080/ | curl: (7) Failed to connect to 192.168.164.131 port 8080 after 3 ms: Could not connect to server | avoidance-legacy.txt (408 B) |

The evidence files were checked with cat and the key lines highlighted. The directory listing shows all seven files (baseline-file, baseline-legacy, baseline-listing, baseline-ports, baseline-web, avoidance-legacy, avoidance-ports), so the before and after states can be compared directly.

Screenshots: Figures 35 to 38 (Appendix A) show the disable command, post-treatment scan, curl failure and saved evidence files.

## 5.4 Why this is avoidance but not elimination of risk

- Avoidance removes the activity that created the exposure. With no process listening on 8080, the retired workflow can no longer be attacked, so R1's exposure is gone for as long as the service stays off.
- The remaining web service is unchanged. At this point Nginx still lists and serves the archive (R2), nothing filters who may connect (R3) and the portal has no backup (R4). The T06 result still shows port 80 open to Kali.
- The unit file still exists on disk and could be re-enabled by mistake or by an update, so residual R1 is not zero. I recommend masking or deleting the unit after the rollback test, and monitoring for drift (Section 9).
- Other exposures such as SSH on port 22 sit outside this treatment and are handled separately.

# 6. Preventive controls (Steps 7 and 8)

Both controls were implemented and tested. Screenshots are Figures 39 to 47 in Appendix A. All Kali tests in this section come from 192.168.164.132, which is also the approved source in the firewall rule.

## 6.1 Step 7 – Remove archive publication (mitigation)

**Design.** Move the archive outside the web root, restrict it to root, set autoindex off and add an explicit denial for the old URL. Moving the file removes publication, the deny rule blocks the retired path, and disabling the listing stops enumeration. I first confirmed after the restart that the portal still worked (Figure 39: ping 4/4, /public/ returned 200 at 06:18:42 GMT) and listed the archive still sitting in the web root (Figure 41).

```
sudo mkdir -p /srv/grc-private
sudo mv /var/www/grc-lab/archive /srv/grc-private/
sudo chmod -R go-rwx /srv/grc-private
sudo nano /etc/nginx/sites-available/grc-lab   # then rewritten with sudo tee (heredoc)
sudo nginx -t
sudo systemctl reload nginx
```

```
server {
    listen 80;
    server_name _;
    root /var/www/grc-lab;
    access_log /var/log/nginx/grc_access.log combined;
    error_log /var/log/nginx/grc_error.log;
    location / { autoindex off; }
    location /archive/ { deny all; }
}
```

nginx -t reported “syntax is ok” and “test is successful”, and Nginx was reloaded (Figures 43 and 44). The Nginx edit was done in the SSH session from Windows PowerShell, as in Section 13. The echoed text of the heredoc looks scrambled in the screenshot because of how the terminal redrew the pasted lines; the configuration test passed and the behaviour below confirms the rules are active.

| ID | Test (Kali 192.168.164.132) | Expected | Actual outcome | Evidence |
|---|---|---|---|---|
| T08 | curl -I /public/ | HTTP 200 | HTTP/1.1 200 OK, Content-Length 25, ETag "6aedd8b1-19" (06:50:43 GMT) | Figure 40; access log line |
| T09 | curl -I /archive/ | HTTP 403 | HTTP/1.1 403 Forbidden (06:50:58 GMT) | Figure 40; access log line |
| T10 | curl -I /archive/dummy-records.txt | HTTP 403 | HTTP/1.1 403 Forbidden (06:51:17 GMT) | Figure 40; access log line |
| T11 | File-system permission check on /srv/grc-private (Ubuntu) | Normal user denied; root-only mode | ls as ubuntu: “Permission denied”. sudo ls shows archive. Directory is drwx------ root root. | Figure 42 |
| T12 | nginx -t and reload (Ubuntu) | Syntax ok; reload succeeds | nginx: configuration file syntax is ok; test is successful. systemctl reload nginx completed. | Figures 43, 44 |

**Reading the results.** The archive and its file now return 403, not 404. A 404 would only say the file is no longer at that path, whereas 403 shows the explicit deny rule matched before any file lookup. The portal itself stayed available (200). The tests were made with curl -I (HEAD requests), so the access log shows them as HEAD with 0 bytes, but the status codes are directly comparable with the baseline GET requests.

**Why disabling listings alone is not enough.** autoindex only controls whether Nginx generates a directory index. If the file stays inside the web root, anyone who knows or guesses the URL is still served the file. T04 at baseline proved this: the dummy file was retrieved directly. Only moving it out of the root and denying the path prevents direct access, and chmod go-rwx adds a second, file-system layer (T11).

## 6.2 Step 8 – Restrict network access with UFW (mitigation)

I switched to the Ubuntu VM console for this step, so enabling the firewall would not drop an SSH session. The approved source is Kali on the host-only network, 192.168.164.132 (its address after DHCP changed, see Section 13).

```
sudo ufw status verbose              # Status: inactive (before)
sudo ufw default deny incoming
sudo ufw default allow outgoing
sudo ufw allow from 192.168.164.132 to any port 80 proto tcp
sudo ufw logging on
sudo ufw enable
sudo ufw status numbered
sudo ufw status verbose
```

| ID | Test | Expected | Actual outcome | Evidence |
|---|---|---|---|---|
| T13 | UFW rule listing (Ubuntu) | Active; default deny incoming; allow 80/tcp from Kali only | Status: active. Logging: on (low). Default: deny (incoming), allow (outgoing). Rule [1]: 80/tcp ALLOW IN 192.168.164.132. Before enabling, status was inactive. | Figures 45, 46 |
| T14 | Approved source after firewall: /public/ and /archive/ | /public/ 200; /archive/ 403 | /public/ HTTP 200 (07:05:56 GMT); /archive/ HTTP 403 (07:06:23 GMT) | Figure 47; access log |
| T15 | nmap -Pn -p 22,80,8080 from Kali (02:06 EST = 07:06 UTC) | 80 open; 22 and 8080 not reachable | 22/tcp filtered ssh; 80/tcp open http; 8080/tcp filtered http-proxy (14.66 s) | Figure 47 |

**Reading the results.** 8080 now shows "filtered" instead of the "closed" seen in T06. Closed means the host answered with a reset (nothing listening); filtered means packets are silently dropped by the firewall. Because the legacy service is also disabled, the filtered result cannot by itself tell the two controls apart, which is why the service status is checked separately in Section 9. Port 22 is filtered even though sshd is still running, so the firewall is the control hiding it. The Windows host (192.168.164.1) is not on the allow list, and its SSH retries appear as blocked packets (Section 7), which shows the firewall is making source-based decisions.

Rollback if a test fails: sudo ufw disable, correct the rule, and re-enable.

# 7. Detection: log correlation (Step 9)

On Ubuntu I reviewed the Nginx access log and the UFW log (Figures 48 and 49):

```
sudo tail -n 20 /var/log/nginx/grc_access.log
sudo grep 'UFW BLOCK' /var/log/ufw.log | tail -n 20
```

### Nginx access log (all from 192.168.164.132, times UTC)

| ID | Time | Request | Status | Phase | Note |
|---|---|---|---|---|---|
| T16a | 06 Nov 20:06:37 | GET / | 200 | Baseline | Root listing (372 bytes) |
| T16b | 06 Nov 20:08:46 | GET /archive/ | 200 | Baseline | Archive listing (285 bytes) |
| T16c | 06 Nov 20:10:49 | GET /archive/dummy-records.txt | 200 | Baseline | File served (34 bytes) |
| T16d | 07 Nov 06:18:42 | GET /public/ | 200 | Post-restart | Portal works (25 bytes) |
| T16e | 07 Nov 06:50:43 | HEAD /public/ | 200 | Treated | Portal available |
| T16f | 07 Nov 06:50:58 | HEAD /archive/ | 403 | Treated | Deny rule |
| T16g | 07 Nov 06:51:17 | HEAD /archive/dummy-records.txt | 403 | Treated | Deny rule |
| T16h | 07 Nov 07:05:56 | HEAD /public/ | 200 | After UFW | Approved source allowed |
| T16i | 07 Nov 07:06:23 | HEAD /archive/ | 403 | After UFW | Deny rule still active |

| Request | Before treatment (6 Nov) | After treatment (7 Nov) |
|---|---|---|
| /public/ | 200 | 200 |
| /archive/ | 200 | 403 |
| /archive/dummy-records.txt | 200 | 403 |

The earlier 200 responses prove the archive was readable before the control, and the later 403 responses for the same source address prove access was restricted. The portal returned 200 throughout, so availability was kept.

### UFW log (UFW BLOCK entries, times UTC)

| ID | Source | Destination port | Time | What it shows |
|---|---|---|---|---|
| T17a | 192.168.164.132 (Kali) | 22/tcp and 8080/tcp | 07:06:59 to 07:07:00 | SYN packets from my Nmap scan were dropped. They line up with the scan started at 02:06 EST (07:06 UTC). |
| T17b | 192.168.164.1 (Windows host) | 22/tcp | 07:09 to 07:10 | My PowerShell SSH retries were dropped by the firewall. This is why SSH from the host stopped working, as designed. |

**What appears where.** Requests from the approved address reach Nginx, so they appear in grc_access.log, including the 403s that show the deny rule working. Traffic the firewall drops never completes a connection to Nginx, so it leaves no Nginx entry and appears as a kernel UFW BLOCK line instead. The two logs are therefore complementary: Nginx shows what the web server allowed or refused; UFW shows what never reached it.

**Limits.** UFW logging is set to low. The UFW lines show only blocked packets, so there is no log line for allowed connections on port 80 other than the Nginx entries. Blocked-packet evidence covers ports 22 and 8080 (from Kali and from the Windows host); the allow rule for port 80 is shown in T13 and T14.

# 8. Corrective control: backup and recovery (Step 10)

Screenshots are Figures 50 to 57. Commands as run on the Ubuntu server:

```
ls -lah /var/www/grc-lab/public/
sudo mkdir -p /srv/grc-backups
sudo chmod 700 /srv/grc-backups
```

```
sudo tar -czpf /srv/grc-backups/grc-portal-backup.tar.gz -C /var/www/grc-lab public
sudo ls -lh /srv/grc-backups/
sha256sum /var/www/grc-lab/public/index.html | tee ~/portal-before.sha256
date -Is | tee ~/portal-backup-time.txt
sudo sha256sum /var/www/grc-lab/public/index.html | sudo tee /srv/grc-backups/portal-before.sha256
date -Is | sudo tee /srv/grc-backups/portal-backup-time.txt
sudo rm /var/www/grc-lab/public/index.html
ls -lah /var/www/grc-lab/public/
sudo tar -xzpf /srv/grc-backups/grc-portal-backup.tar.gz -C /var/www/grc-lab
ls -lah /var/www/grc-lab/public/
sudo sha256sum -c /srv/grc-backups/portal-before.sha256
```

| ID | Check | Expected | Actual outcome | Evidence |
|---|---|---|---|---|
| T18 | Backup archive created in a mode-700 directory | Archive present | grc-portal-backup.tar.gz, 181 bytes, created 07:26 UTC in /srv/grc-backups (directory chmod 700) | Figure 50 |
| T19 | SHA-256 of original index.html recorded | Hash saved | Hash recorded (begins e5b34d9b, ends 53a50f72; full value in Figure 51). Saved to ~/portal-before.sha256 (07:38:26) and again to /srv/grc-backups/portal-before.sha256 (07:49). | Figures 51, 52 |
| T20 | Loss confirmed after deletion | Portal page gone | index.html deleted; public directory empty (modified 07:54). Kali /public/ returned HTTP 403 Forbidden at 07:58:17 GMT. | Figures 53, 54 |
| T21 | Restore and integrity check | index.html restored; hash OK | tar -xzpf restored index.html (25 bytes, original timestamp Nov 6 13:40). sha256sum -c: /var/www/grc-lab/public/index.html: OK | Figures 55, 56 |
| T22 | Service check after restore (Kali) | HTTP 200, original content | HTTP/1.1 200 OK at 08:05:25 GMT. Content-Length 25, Last-Modified 06 Nov 13:40:01, ETag "6aedd8b1-19", identical to the pre-deletion response. | Figure 57 |
| T23 | Observed recovery time | Measured | About 11 minutes: deletion at 07:54 (directory modified time) to verified restoration at 08:05:25 GMT (Kali). A date -Is end time was not recorded. | Timeline below |

### Timeline (UTC)

| Time | Event |
|---|---|
| 07:26 | Backup archive created (181 bytes) |
| 07:38:26 | First timestamp recorded, hash saved to the home directory |
| 07:49 / 07:52:07 | Hash and timestamp saved into /srv/grc-backups (start-of-test record) |
| 07:54 | index.html deleted |
| 07:58:17 | Kali confirms /public/ returns 403 |
| not captured | Restore command and hash check (no timestamp shown) |
| 08:05:25 | Kali confirms /public/ returns 200 with identical headers |

**Integrity evidence.** Two independent checks agree that the restored file is the original: sha256sum -c reports OK, and the HTTP response after restore has the same Content-Length, Last-Modified and ETag as before deletion. The 403 seen while the file was missing also confirms that autoindex stays off even for the public folder.

**How to read the recovery time.** The 11 minutes is dominated by typing commands, switching windows and taking screenshots; the restore itself takes seconds for one 25-byte file on a quiet lab server. It is evidence that recovery works, not a production recovery time objective. For a cleaner figure the test can be repeated with date -Is before the delete and after the hash check.

**Limitation.** The backup is on the same host as the data. It protects against accidental deletion or corruption of a file, which is what this test covers, but not against loss of the whole host, disk failure, ransomware or a compromise that lets an attacker delete both copies. That gap is why option B (an off-host managed backup) is evaluated in Section 10. The backup archive file is world-readable (rw-r--r--) but sits inside a directory restricted to root.

# 9. Monitoring and operational handover

The table below is a **proposed** ongoing monitoring plan. It is not a measured result. The measured lab results are in Sections 3 and 5 to 8.

| Check | Owner | Frequency | Threshold | Escalation | Method |
|---|---|---|---|---|---|
| Approved portal availability | IT Operations Manager | Every 5 minutes | HTTP 200 on /public/; alert on 2 consecutive failures | Operations on-call, then Head of IT Operations if down >15 min | curl -s -o /dev/null -w "%{http_code}" http://SERVER/public/ |
| Unexpected open ports | Network and Security Lead | Weekly and after any change | Only 80/tcp open from the approved source; any other open port is a finding | Open a high-priority ticket within 4 hours; Security Lead reviews | nmap -sT -p 1-1024,8080 from Kali; sudo ss -lntp on server |
| Recovery-test success | IT Operations Manager | Monthly | Restore completes, SHA-256 matches (100%), recovery time within the agreed target [Assumption: 15 minutes] | Failed test escalated to Head of IT Operations; re-test within 5 working days | tar restore + sha256sum -c, with date -Is timing |
| Configuration drift: retired service | Network and Security Lead | Daily | grc-legacy must be disabled or masked and nothing listening on 8080 | Any listener on 8080 is an immediate security incident; stop the service and review the change record | systemctl is-enabled grc-legacy; ss -lntp \| grep 8080 |

Handover notes: record the final UFW rules, Nginx configuration and backup location in the change log; review R1 to R4 after each change; and keep evidence for at least the retention period set in the managed-backup clause.

# 10. Treatment decision record (Step 11)

## 10.1 Four-strategy summary

| Strategy | Risk and action | Result / status | Why chosen |
|---|---|---|---|
| Avoidance | R1: retire the legacy endpoint (CR-001) | Implemented and verified (T06, T07, ss output) | The service has no business purpose, so removing it is cheaper and stronger than securing it. |
| Mitigation | R2: move archive, deny path, autoindex off. R3: UFW source allow-list and logging. R4: tested backup and restore | Implemented and tested (T08–T23); open gaps listed in Section 13 | The portal must stay available, so the exposure can only be reduced, not removed. |
| Transfer | R4: managed off-host backup (option B) | Modelled only. No purchase and no real contract. | Provides an off-host copy and provider restore testing, but does not remove the technical risk. |
| Acceptance | Plain HTTP on isolated network with dummy data (temporary) | Simulated approval, 14-day expiry | Impact is low while only dummy data is on an isolated host-only network. |

## 10.2 Transfer: managed backup compared with local-only backup

| Factor | Local-only backup (as tested) | Managed backup (fictional offer: $120 setup + $20/month) |
|---|---|---|
| First-year cash cost | $0 extra (labour only) | $120 + (12 × $20) = $360 |
| Location | Same host (/srv/grc-backups) | Separate provider location |
| Protects against | Accidental file deletion or corruption | Deletion, host loss, disk failure (if provider copy is intact) |
| Does not protect against | Host loss, ransomware, compromise | Unauthorised access, misconfiguration or compromise at source |
| Restore testing | Done by me (Section 8) | Required monthly under the clause below |

**Draft service clause (fictional, for discussion only).**

- **Provider duties:** take an encrypted backup of the Northbridge portal content every 24 hours, store it away from the production host, retain it for at least 30 days, run and report a restoration test at least monthly including SHA-256 verification, and restore content within 4 hours of an authorised request in business hours. [Assumption: proposed values]
- **Retained customer duties:** keep the authorised contact list and approve restores, protect credentials and the host configuration, supply and maintain the hash manifest, and verify restored content.
- **Evidence retention:** the provider keeps backup job logs and test reports for 12 months and supplies them within 5 working days of request.
- **Service limitation:** the service only recovers data captured in a completed backup (24-hour recovery point), does not prevent unauthorised access or misconfiguration, and does not transfer Northbridge's accountability. A contract or insurance does not remove the technical risk.

## 10.3 Acceptance: temporary use of plain HTTP

| Field | Entry |
|---|---|
| Risk accepted | Traffic between Kali and the Ubuntu server is unencrypted (HTTP), so content and requests could be read by anything on the segment. |
| Risk owner | IT Operations Manager. SIMULATED. |
| Residual score | Likelihood 2 × impact 2 = 4 (Low). Judgement based on dummy data only, isolated host-only network, and firewall restricted to one approved source (Section 6.2). |
| Rationale | No real data, no external route, no other users. Cost of TLS ($100) is not justified yet. Within classroom appetite (Low). |
| Approval | Simulated approval dated 6 Nov 2026. |
| Expiry / review | Expires 20 November 2026 (14 days). Interim review 13 November 2026; final review 19 November 2026. |
| Triggers for early review | Any real or personal data; NAT, bridged or other external connectivity; additional clients or users; firewall rules widened or UFW disabled; failed control test. Any trigger means deploy option C (TLS) or stop the service. |

## 11. Cost and benefit analysis (Step 12)

All prices are fictional figures from the brief [Assumption]. First-year cost = setup + labour + annual recurring cost.

| Option | Setup | Labour | Annual recurring | Total | Calculation |
|---|---|---|---|---|---|
| A Hardening work | $0 | 4 h × $25 = $100 | $50 maintenance | $150 | 100 + 50 |
| B Managed backup | $120 | $0 | 12 × $20 = $240 | $360 | 120 + 240 |
| C TLS deployment | $0 | 3 h × $25 = $75 | $25 maintenance | $100 | 75 + 25 |

| Combination | First-year cost | Comment |
|---|---|---|
| A only | $150 | Covers R1 to R3 but leaves same-host backup limitation (R4). |
| A + C | $250 | Adds encryption but not off-host recovery. |
| A + B (recommended) | $510 | Covers R1 to R4 and the off-host recovery gap. TLS deferred under time-limited acceptance. |
| A + B + C | $610 | Full package. Adopt C as soon as any acceptance trigger occurs. |

**Justification.** Option A is the cheapest and directly implements the treatments I tested (service retirement, archive removal, firewall, logging). Option B addresses the weakness I identified in the same-host backup. Option C improves confidentiality in transit but, with dummy data on an isolated network, the benefit is currently small, so I recommend deferring it under the 14-day acceptance and making it mandatory before real data is used. The options are not independent and their benefits overlap, so I do not add benefits together.

**Excluded costs:** host hardware and VM licensing, electricity, analyst time spent on assessment and reporting, ongoing monitoring staff time, training, provider restore or egress fees, certificate and renewal costs for TLS, management time, tax, and costs after year one (for example A + B recurring is $290 per year after setup).

### Illustrative backup scenario (option B only)

| Item | Calculation | Value |
|---|---|---|
| Annual rate of occurrence (ARO) | given | 0.2 per year |
| Loss per event, no tested recovery | given | $5,000 |
| Baseline ALE | 0.2 × $5,000 | $1,000 |
| Loss per event with tested recovery | given | $1,000 |
| Residual ALE | 0.2 × $1,000 | $200 |
| Annual benefit | $1,000 − $200 | $800 |
| First-year cost of B | $120 + $240 | $360 |
| First-year net benefit | $800 − $360 | $440 |

Every figure above is an assumption. My recovery test shows only that one dummy file can be restored and how long that took; it does not establish the occurrence rate or the loss amounts. I have not converted the ordinal risk scores into dollar savings and I have not added any benefit from options A or C to this calculation.

# 12. Residual risk reassessment

Residual scores below are my judgement after the tests in this report. Likelihood and impact remain ordinal classroom scores, not measurements.

| ID | Baseline (L×I) | Residual (L×I) | Status | Evidence | Owner | Review trigger |
|---|---|---|---|---|---|---|
| R1 | 4×4 = 16 High | 1×4 = 4 Low | Measured | T06, T07, ss output; avoidance-*.txt; 8080 filtered in T15 | IT Operations Manager | Any listener on 8080, grc-legacy re-enabled, or change touching the unit. Unit file still on disk. |
| R2 | 4×5 = 20 Critical | 1×5 = 5 Medium | Measured | T08–T12, T16e–T16i; Figures 40–44 | Records Owner / Data Owner | Any file placed under /var/www, config change, or a 200 on /archive/ |
| R3 | 3×5 = 15 High | 1×5 = 5 Medium | Measured | T13–T15, T17; Figures 45–49 | Network and Security Lead | New client, rule change, UFW disabled, external connectivity. An IP allow-list is not authentication and source addresses can be spoofed on a shared segment. |
| R4 | 3×4 = 12 High | 3×3 = 9 Medium | Measured | T18–T23; Figures 50–57 | IT Operations Manager | Failed monthly restore test, host change, or real data. Impact stays at 3 while the only backup is on the same host. |

**Reading the movement.** The treatments cut likelihood for R1 to R3 because the exposure was removed or filtered. R4 is a corrective control, so it lowers impact (recovery proved) but not likelihood. R1 falls into the Low band. R2, R3 and R4 stay Medium rather than Low because of the limits noted above. Separately, the accepted risk of plain HTTP is recorded as 4 (Low) with a 14-day expiry (Section 10.3).

# 13. Issues log, limitations and evidence gaps

## 13.1 Things that happened during the lab

| Item | Detail and handling |
|---|---|
| Keyboard fault and SSH use | The "{" key stopped working, so I could not type the Nginx server block at the console. I stopped grc-legacy, shut the VM down, temporarily enabled NAT, installed openssh-server, enabled ssh, and connected from Windows PowerShell (192.168.164.1) to 192.168.164.131. The journal shows "Accepted password for ubuntu from 192.168.164.1". I used the same SSH route for the Step 7 Nginx edit. I enabled UFW at the VM console so it would not cut a session. No password appears in any evidence. |
| Kali address changed | Kali's host-only address was 192.168.164.128 at the first connectivity check, but the Nginx log shows requests from 192.168.164.132 from the baseline onward (DHCP lease change). All baseline, treatment and firewall tests therefore come from .132, and the UFW allow rule uses .132. After the restart Kali's host-only adapter appeared as eth0 and eth1 was no longer present, so any eth1 command from the brief was adapted. |
| SSH still enabled | sshd still listens on 22. It is not reachable from Kali or the host while UFW is on (22 shows filtered in T15; blocked in the UFW log), but the service is an unnecessary exposure. Recommended: sudo systemctl disable --now ssh.socket ssh.service, then capture sudo ss -lntp. |
| Service startup typo | WantedBy== in the unit file caused the first enable to fail. Corrected, then reloaded. The service was stopped before shutdown but remained enabled, consistent with it listening again after reboot (python3 PID 1158 in the baseline ss output). |
| Harmless command errors | Mistyped commands ("ubuntu", "ye"), invalid systemctl options (-1, -I) and a first ls of /srv/grc-private without sudo (Permission denied, which is the expected result of the control) changed nothing. |
| Scrambled heredoc echo | The Step 7 Nginx heredoc echoed with garbled lines in the SSH terminal. nginx -t passed and the 403 behaviour confirms the rules are active. |

| Item | Detail and handling |
|---|---|
| HEAD requests | Post-treatment tests used curl -I (HEAD). Status codes are comparable with the baseline GET requests; the Nginx log marks them HEAD. |
| Time zones | Ubuntu logs and Nginx are UTC. Kali shell and Nmap times are EST (UTC−5), so 02:06 EST on 7 Nov = 07:06 UTC. All timestamps are labelled. |

## 13.2 Limitations of the evidence

- **Source-based blocking** is shown for ports 22 and 8080 (UFW BLOCK entries for Kali and for the Windows host, and Nmap "filtered" results). The portal on port 80 was tested from the approved source only, so the report does not claim a blocked-source result for port 80.
- **Rollback of CR-001** is documented as a procedure but was not executed. The legacy service was left disabled.
- **Recovery time** was recorded from manual steps and timestamps visible in the screenshots (about 11 minutes). It is not a production recovery time objective.
- **SSH** was left enabled on the server after the lab. The firewall filters it, but disabling it (sudo systemctl disable --now ssh.socket ssh.service) is recommended hardening.
- **Backup location:** the only backup is on the same host as the data, so it does not cover host loss or compromise. That is why a managed off-host backup (option B) is evaluated.
- **Costs and loss figures** are fictional assumptions. Risk scores are classroom judgements.

# 14. Evidence index and README mapping

| ID | File / artefact | Step | Description | Status |
|---|---|---|---|---|
| E01 | Figures 1–2, 6–7: ip -br addr and ping (Ubuntu and Kali) | 1 | Addresses and connectivity | Have |
| E02 | Figures 3–5: install, versions, VMware settings | 1 | Software versions and VM spec | Have |
| E03 | Figures 9–19: directories, index files, unit file, status | 2 | Content and legacy service | Have |
| E04 | Figures 20–27: SSH install and session, Nginx config, nginx -t, reload | 3 | Web service | Have |
| E05 | baseline-ports/web/listing/file/legacy.txt; Figures 28–33 | 4 | Baseline outputs | Have |
| E06 | baseline-time.txt; ufw status verbose before enabling (Figure 45 shows inactive) | 4 | Baseline timestamp and firewall state | Have |
| E07 | ss -lntp: Figure 34 (baseline), Figure 35 (after avoidance) | 4, 6 | Listening sockets | Have |
| E08 | Baseline risk register (Section 4) and workbook | 5 | Scores and gaps | Have |
| E09 | avoidance-ports.txt, avoidance-legacy.txt; Figures 36–38 | 6 | Post-avoidance results | Have |
| E11 | Figures 39–44: post-restart check, treated curl tests, archive move, Nginx config, reload | 7 | Archive hardening | Have |
| E12 | Figures 45–47: UFW commands, rule listing, approved and Nmap tests | 8 | Firewall validation | Have |
| E13 | Figures 48–49: Nginx access log and UFW BLOCK entries | 9 | Log correlation | Have |
| E14 | Figures 50–57: backup, hash, deletion, 403, restore, hash OK, 200 | 10 | Recovery | Have |
| E15 | GRC103_Cost_and_Risk_Calculations.xlsx (risk register, costs, ALE) | 11, 12 | Costs and ALE | Have |

**README outline for the ZIP (This will be in my gitlab readme)**

- Lab overview and addresses (Ubuntu 192.168.164.131; Kali 192.168.164.128 at first check and 192.168.164.132 from baseline).
- Folder map: /baseline, /avoidance, /preventive, /logs, /recovery, /configs, /calculations, /screenshots.
- For each step: commands run, evidence file names or figure numbers, and the report section that uses them.
- Redaction note: no passwords, private keys or VM disk images are included. Redact any secrets from screenshots and logs before zipping.
- Statement distinguishing measured results, simulated approvals and assumptions.

# Appendix A. Screenshot evidence

Screenshots taken during the lab, in the order they were captured. They support the measured results in Sections 2 to 8. Figure numbers can be cited in the README.

**Figure 1. Ubuntu 26.04.1 LTS: release check and ip -br addr (NAT address 192.168.233.131)**

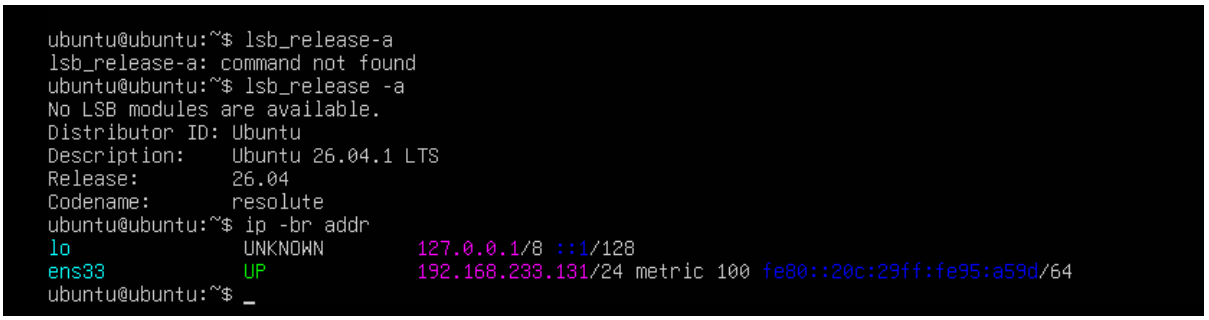



**Figure 2. Ubuntu: internet connectivity via NAT (ping ubuntu.com, 0% loss)**

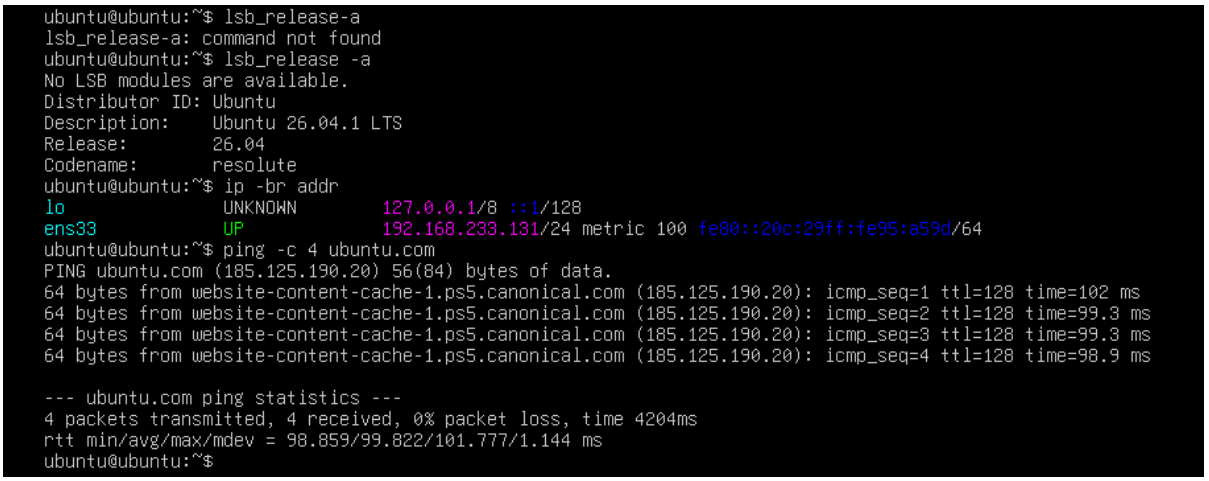



**Figure 3. Ubuntu: installation of nginx**

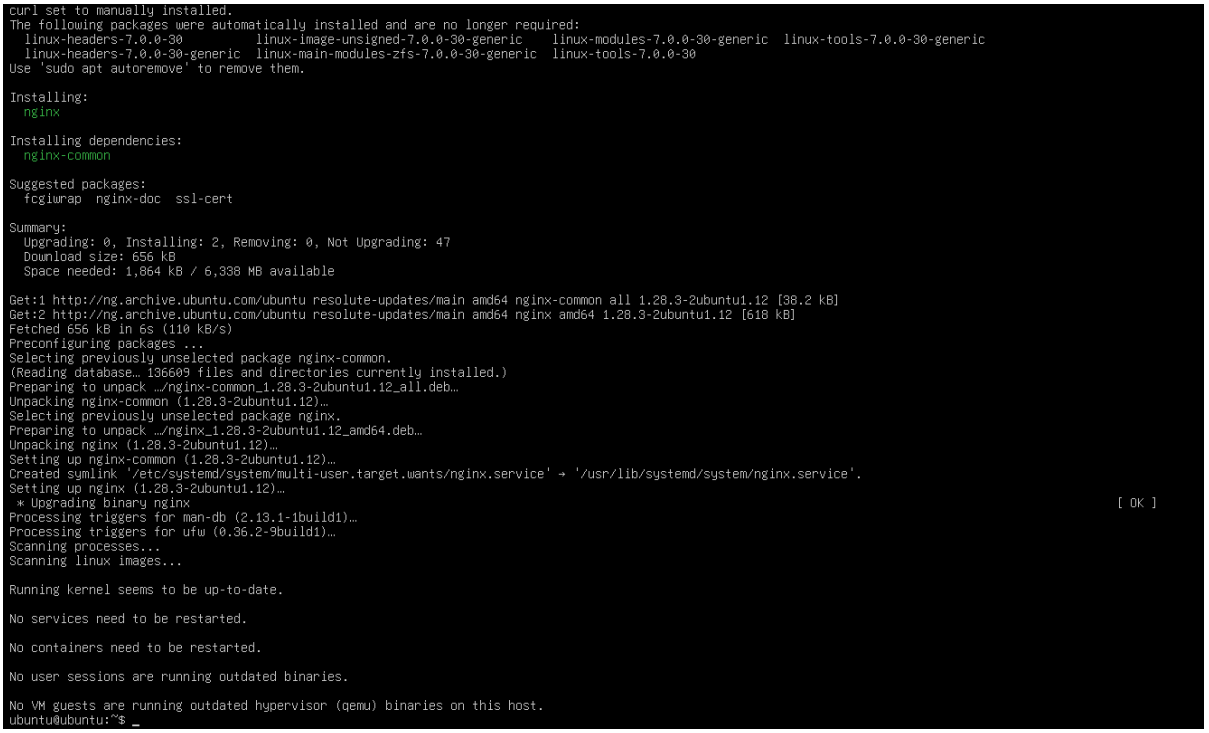


**Figure 4. Ubuntu: nginx, ufw, Python and curl versions**




**Figure 5. VMware settings for the Ubuntu VM (4 GB RAM, 2 processors, 20 GB disk, host-only adapter)**

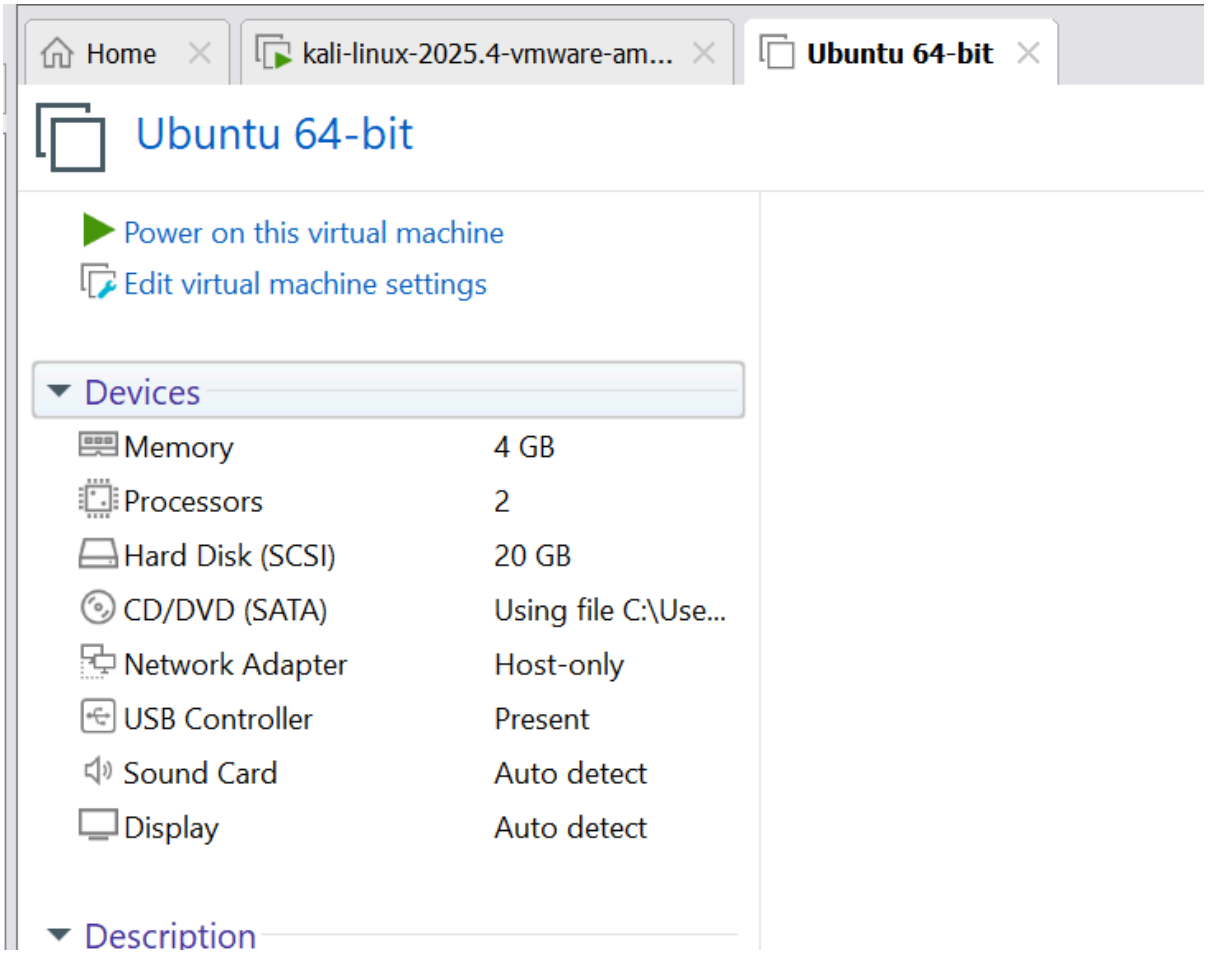


Figure 6. Kali: ip -br addr (eth0 NAT, eth1 host-only 192.168.164.128) and ping to 192.168.164.131

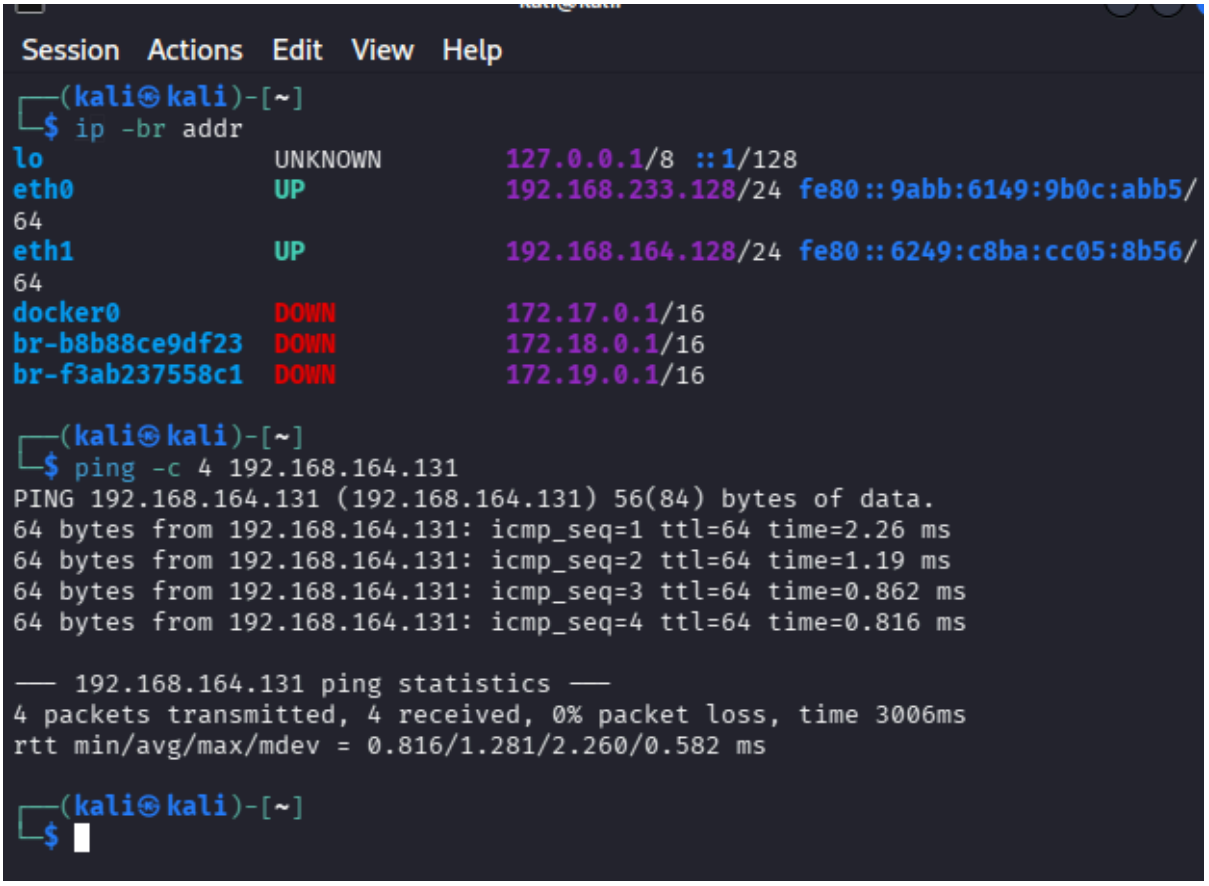



Figure 7. Ubuntu: login and ip -br addr on host-only network (192.168.164.131)

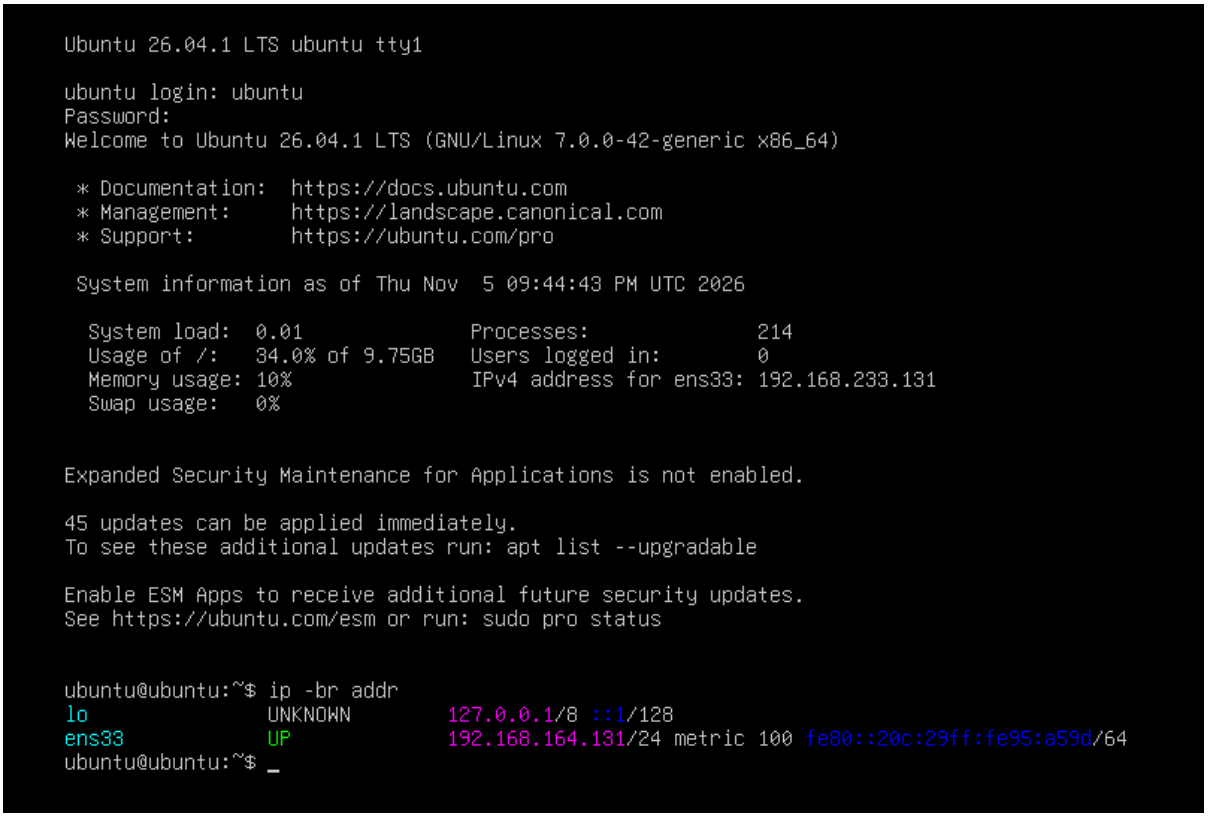


**Figure 8. Ubuntu: ping to Kali 192.168.164.128 (0% loss)**

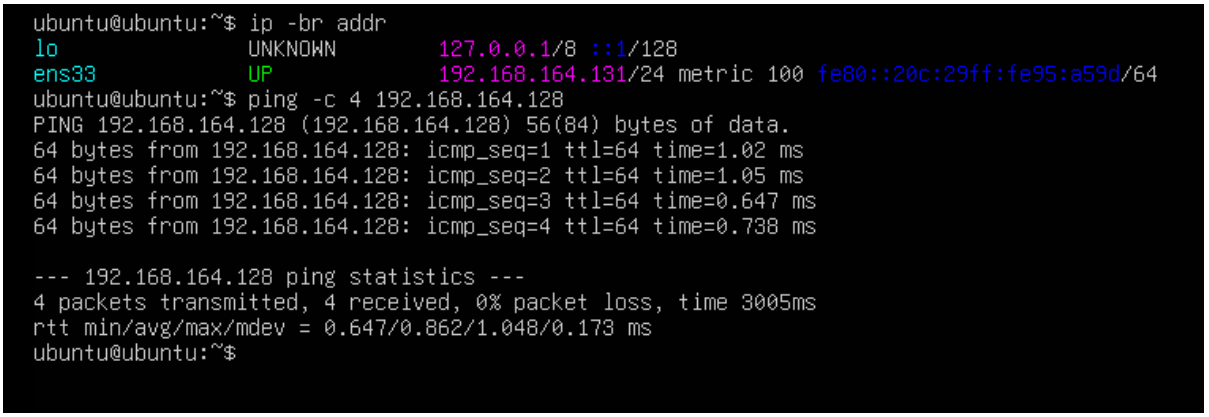



**Figure 9. Ubuntu: creation of the lab directories**

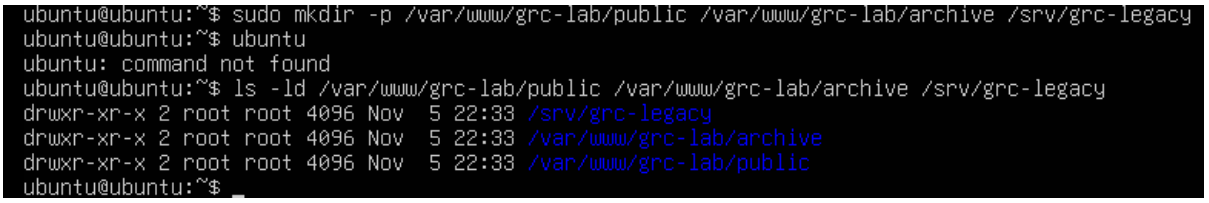



**Figure 10. Ubuntu: creation of the approved portal index.html**

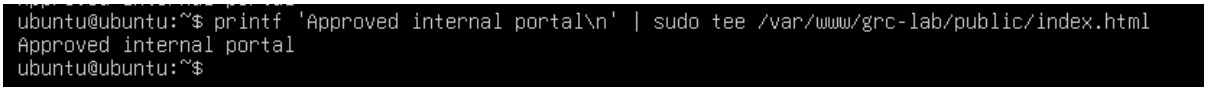



**Figure 11. Ubuntu: portal index.html file listing**

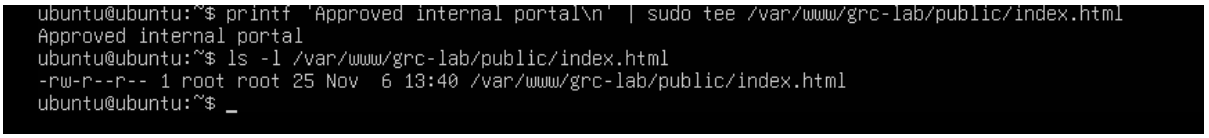



**Figure 12. Ubuntu: creation of dummy-records.txt and legacy index.html, chmod a+rX**




**Figure 13. Ubuntu: legacy service unit file in nano**

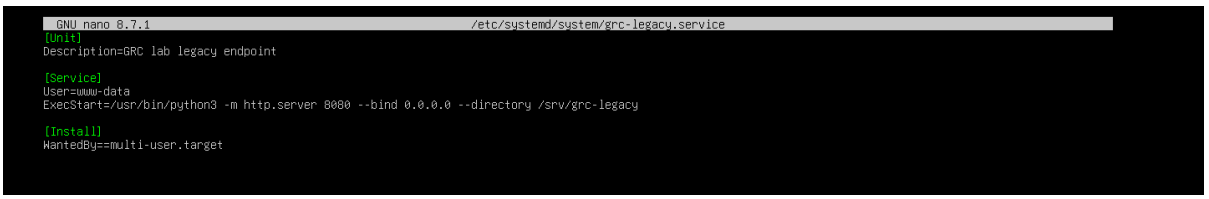


**Figure 14. Ubuntu: legacy service unit file contents (sudo cat)**




**Figure 15. Ubuntu: first enable attempt fails (Invalid unit name =multi-user.target)**

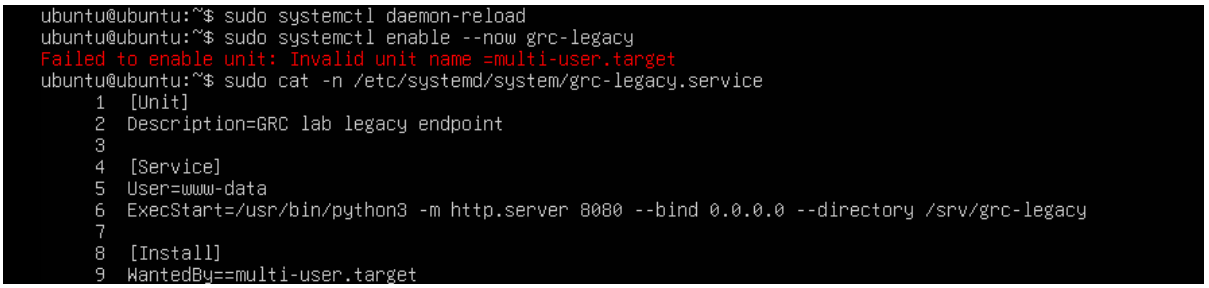



**Figure 16. Ubuntu: unit file edited to correct the typo**




**Figure 17. Ubuntu: service status after the typo (disabled, inactive)**

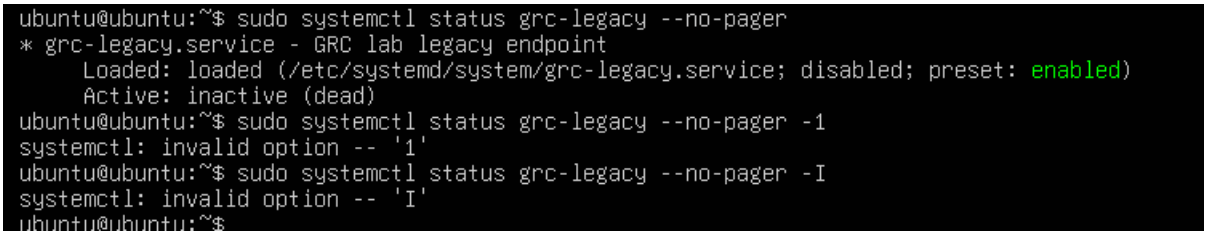



**Figure 18. Ubuntu: grc-legacy enabled and active (running), PID 3743**

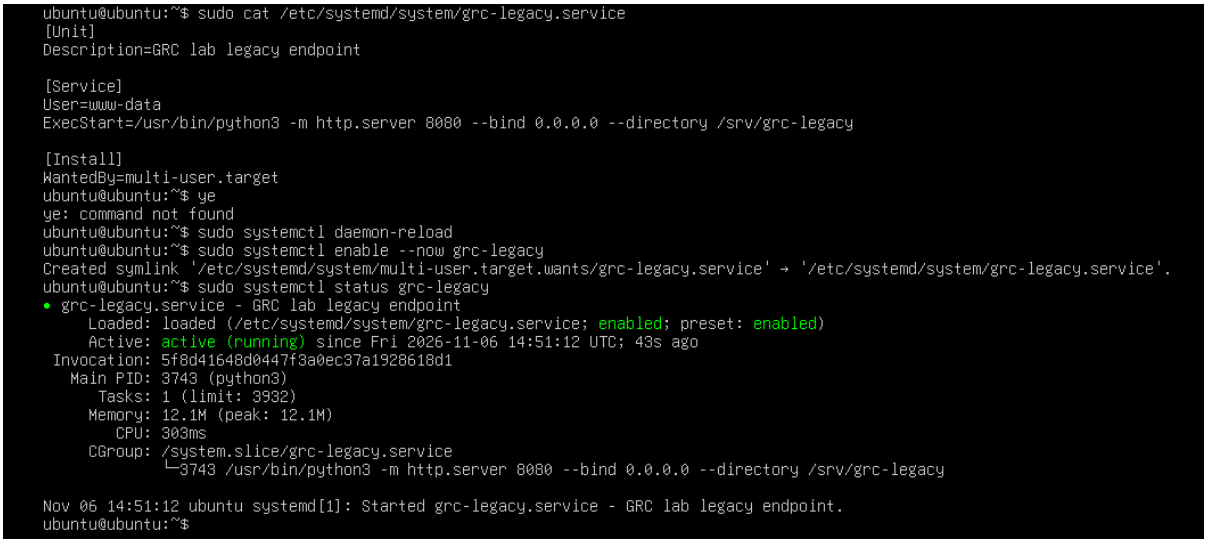


**Figure 19. Ubuntu: nginx service active (running)**

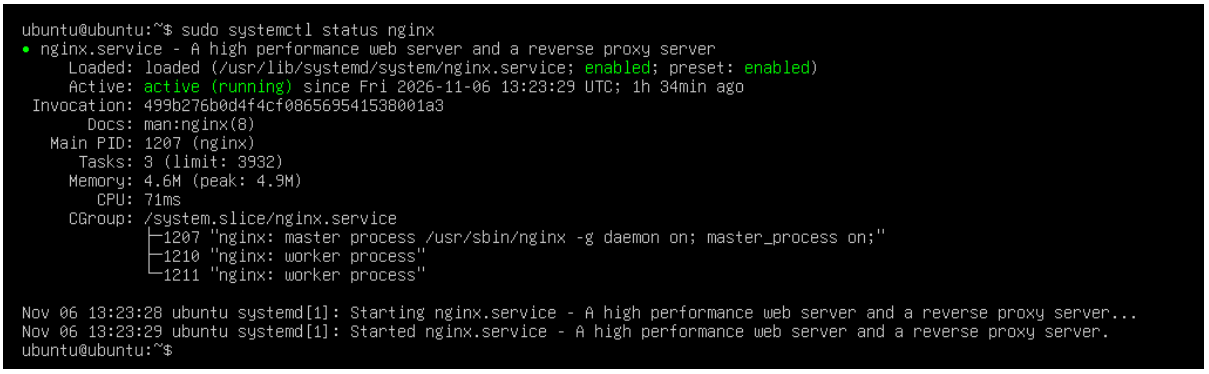



**Figure 20. Ubuntu: nginx site file created, grc-legacy stopped, VM shutdown (keyboard fault)**




**Figure 21. Ubuntu: installation of openssh-server**

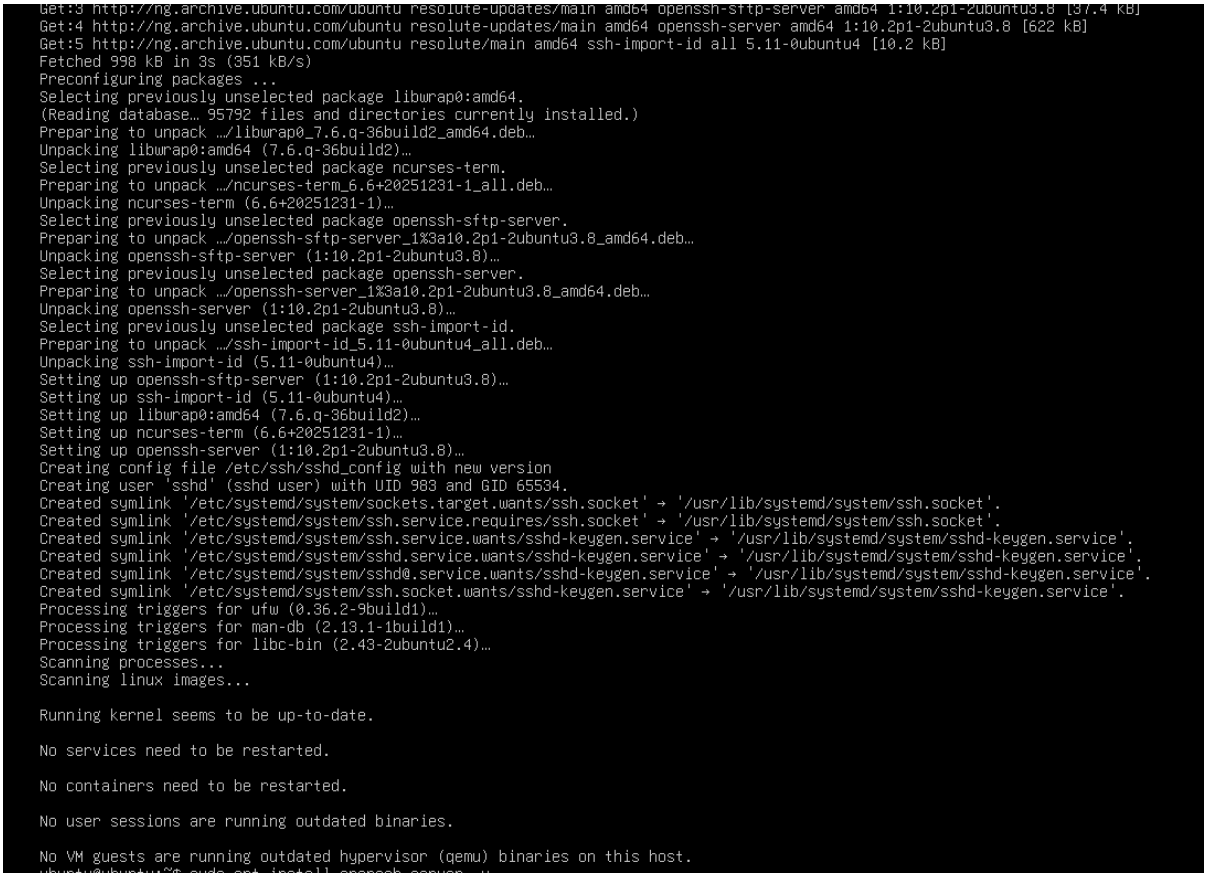



**Figure 22. Ubuntu: ssh enabled with systemctl**

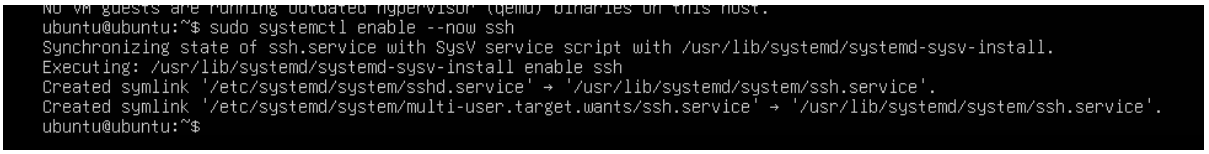


**Figure 23. Ubuntu: ip -br addr after returning to host-only (192.168.164.131)**

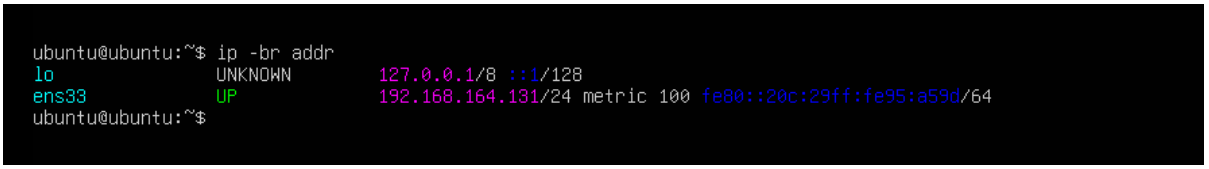



**Figure 24. Windows PowerShell: SSH session to 192.168.164.131**

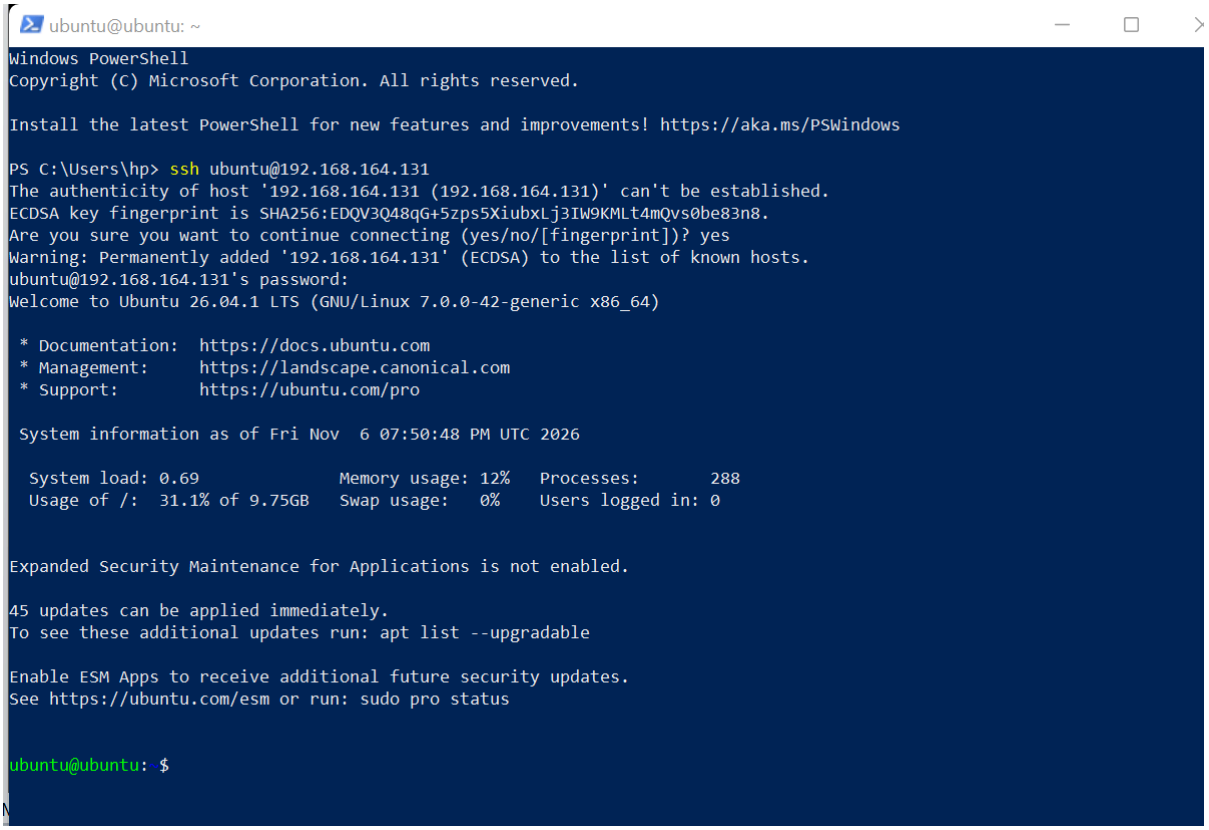



**Figure 25. Ubuntu: ssh service status and accepted login from 192.168.164.1**



Figure 26. Ubuntu (via SSH): Nginx grc-lab server block, symlink, nginx -t successful

```
ubuntu@ubuntu:~$ sudo tee /etc/nginx/sites-available/grc-lab > /dev/null <<'EOF'
> server {
>     listen 80;
>     server_name _;
>     root /var/www/grc-lab;
>     access_log /var/log/nginx/grc_access.log combined;
>     error_log /var/log/nginx/grc_error.log;
>     location / { autoindex on; }
> }
> EOF
ubuntu@ubuntu:~$ sudo ln -s /etc/nginx/sites-available/grc-lab /etc/nginx/sites-enabled/grc-lab
ubuntu@ubuntu:~$ sudo rm -f /etc/nginx/sites-enabled/default
ubuntu@ubuntu:~$ sudo nginx -t
nginx: the configuration file /etc/nginx/nginx.conf syntax is ok
nginx: configuration file /etc/nginx/nginx.conf test is successful
ubuntu@ubuntu:~$
```

Figure 27. Ubuntu: nginx reloaded

```
ubuntu@ubuntu:~$ sudo systemctl reload nginx
ubuntu@ubuntu:~$
```

Figure 28. Kali: evidence folder, SERVER_IP and baseline Nmap scan (ports 80 and 8080 open)

```
┌──(kali㉿kali)-[~]
└─$ mkdir -p ~/grc-treatment-evidence

┌──(kali㉿kali)-[~]
└─$ cd ~/grc-treatment-evidence

┌──(kali㉿kali)-[~/grc-treatment-evidence]
└─$ pwd
/home/kali/grc-treatment-evidence

┌──(kali㉿kali)-[~/grc-treatment-evidence]
└─$ SERVER_IP=192.168.164.131

┌──(kali㉿kali)-[~/grc-treatment-evidence]
└─$ nmap -sT -p 80,8080 "$SERVER_IP" -oN baseline-ports.txt
Starting Nmap 7.95 ( https://nmap.org ) at 2026-11-06 15:05 EST
Nmap scan report for 192.168.164.131
Host is up (0.0018s latency).

PORT     STATE SERVICE
80/tcp   open  http
8080/tcp open  http-proxy
MAC Address: 00:0C:29:95:A5:9D (VMware)

Nmap done: 1 IP address (1 host up) scanned in 13.40 seconds

┌──(kali㉿kali)-[~/grc-treatment-evidence]
```

**Figure 29. Kali: baseline curl of / (HTTP 200, directory listing shows archive/ and public/)**

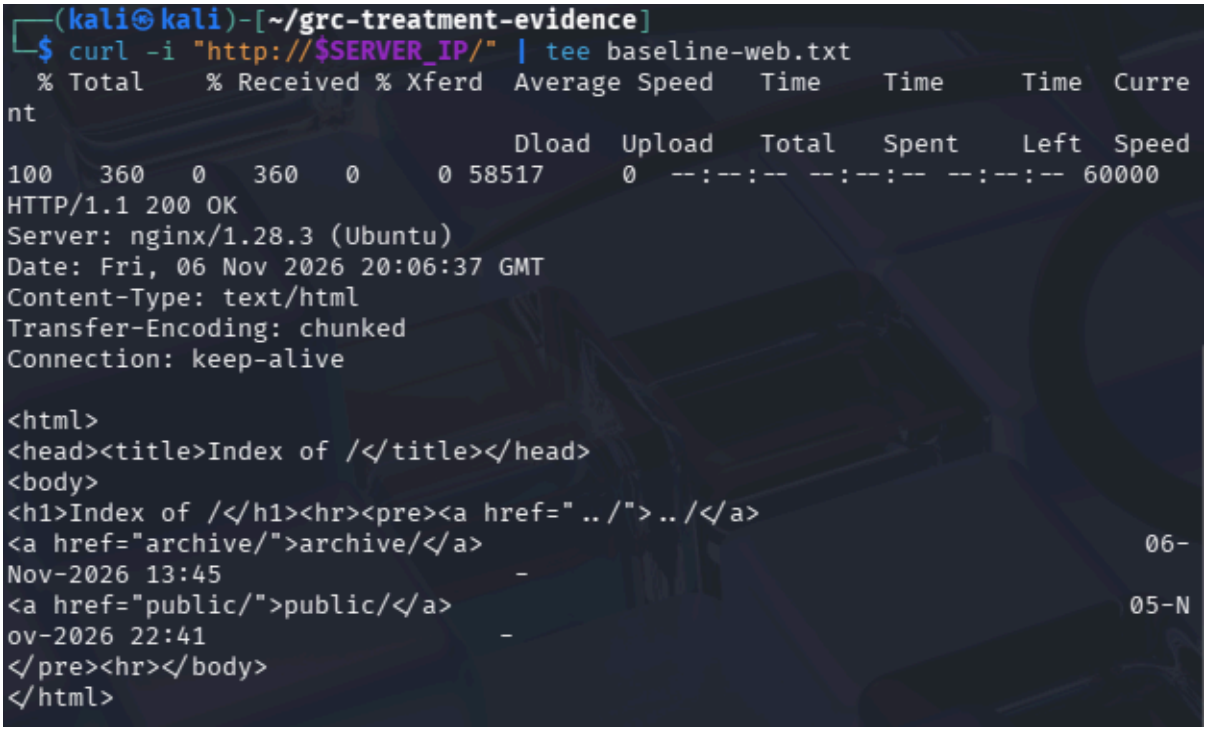



**Figure 30. Kali: baseline curl of /archive/ (HTTP 200, listing)**



Figure 31. Kali: baseline curl of /archive/dummy-records.txt (HTTP 200)

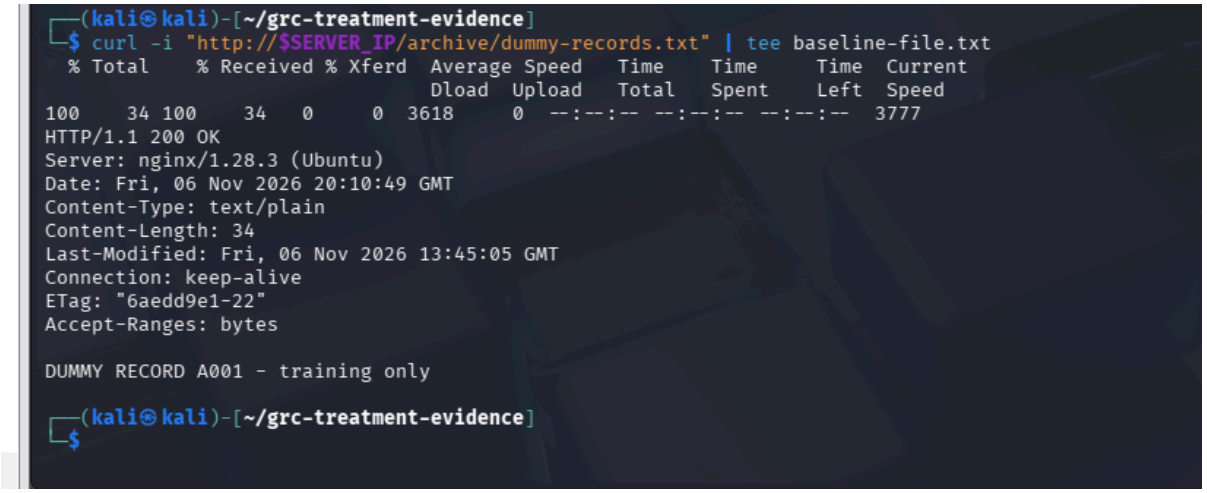



Figure 32. Kali: baseline curl of legacy service on 8080 (HTTP 200, SimpleHTTP/0.6)

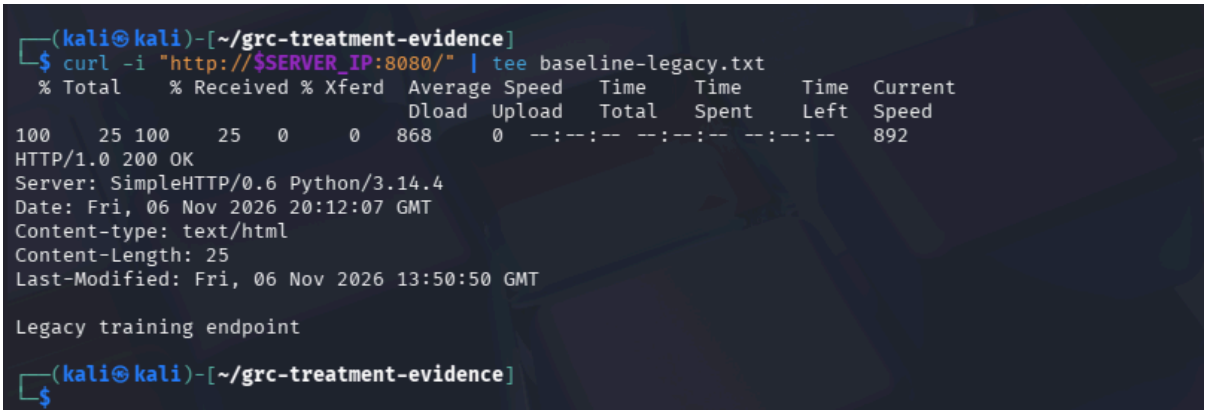



Figure 33. Kali: baseline evidence files saved (ls -l)

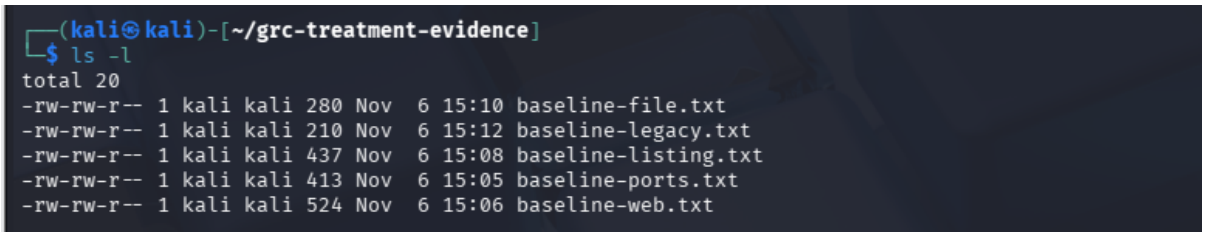



Figure 34. Ubuntu: baseline sudo ss -lntp (22, 80, 8080 listening)

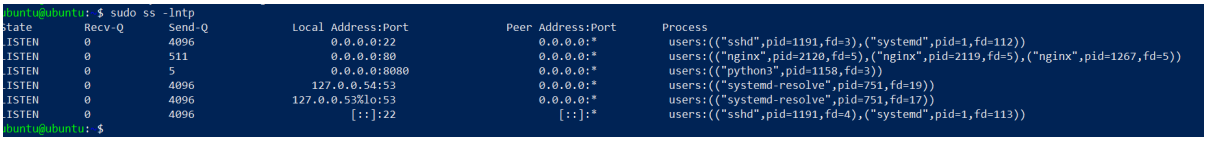



Figure 35. Ubuntu: grc-legacy disabled, is-active inactive, ss -lntp shows no 8080 listener

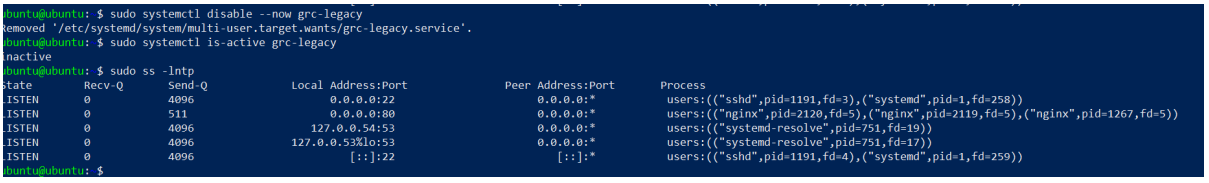


Figure 36. Kali: post-avoidance Nmap (8080 closed) and curl failure to 8080

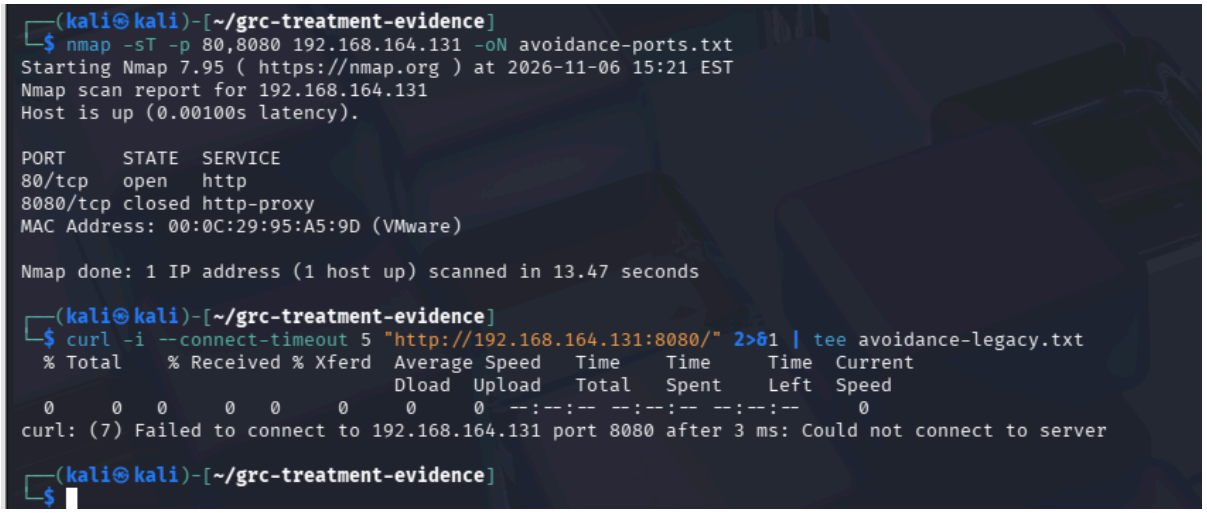



Figure 37. Kali: contents of avoidance-ports.txt and avoidance-legacy.txt with key lines highlighted

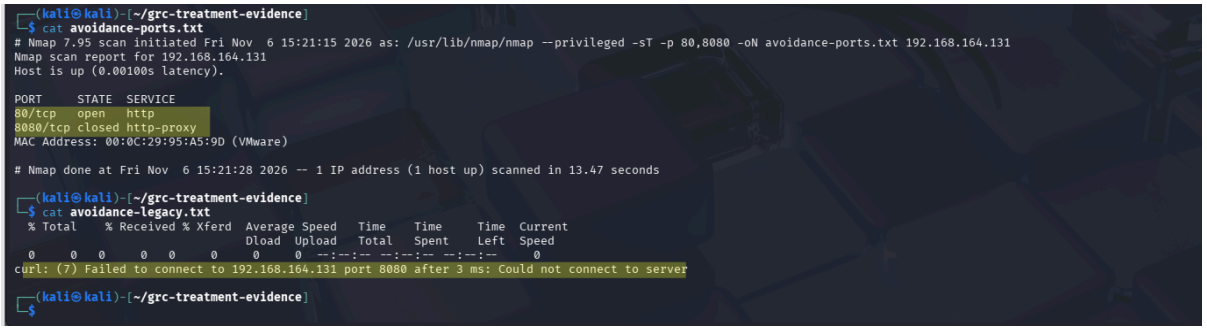



Figure 38. Kali: evidence directory listing (baseline and avoidance files)

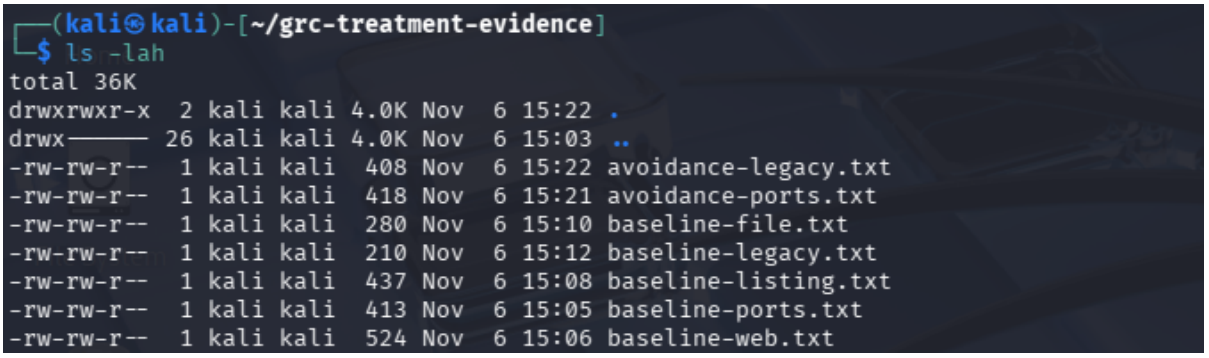


Figure 39. Kali: post-restart ping to 192.168.164.131 and curl of /public/ (HTTP 200) before Step 7 changes

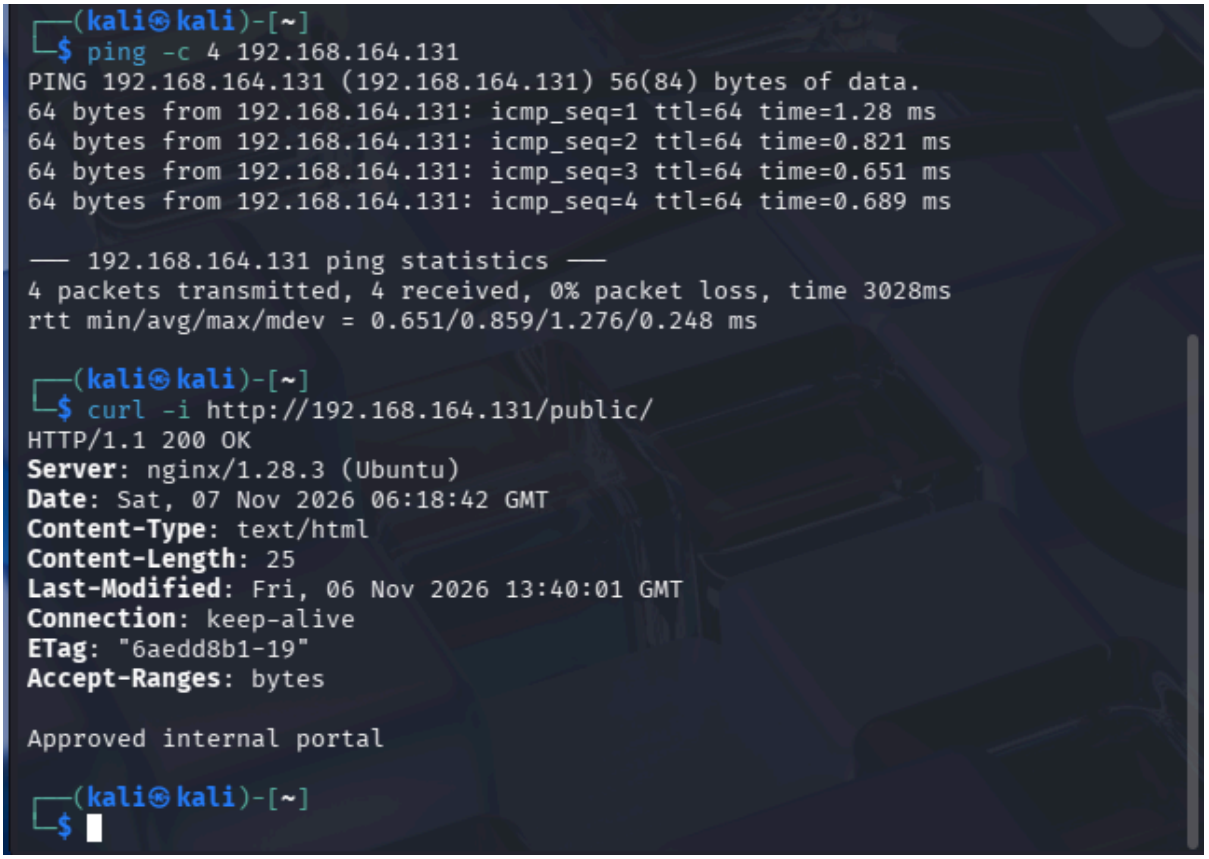



Figure 40. Kali: Step 7 tests, /public/ 200, /archive/ 403, /archive/dummy-records.txt 403 (HEAD requests)

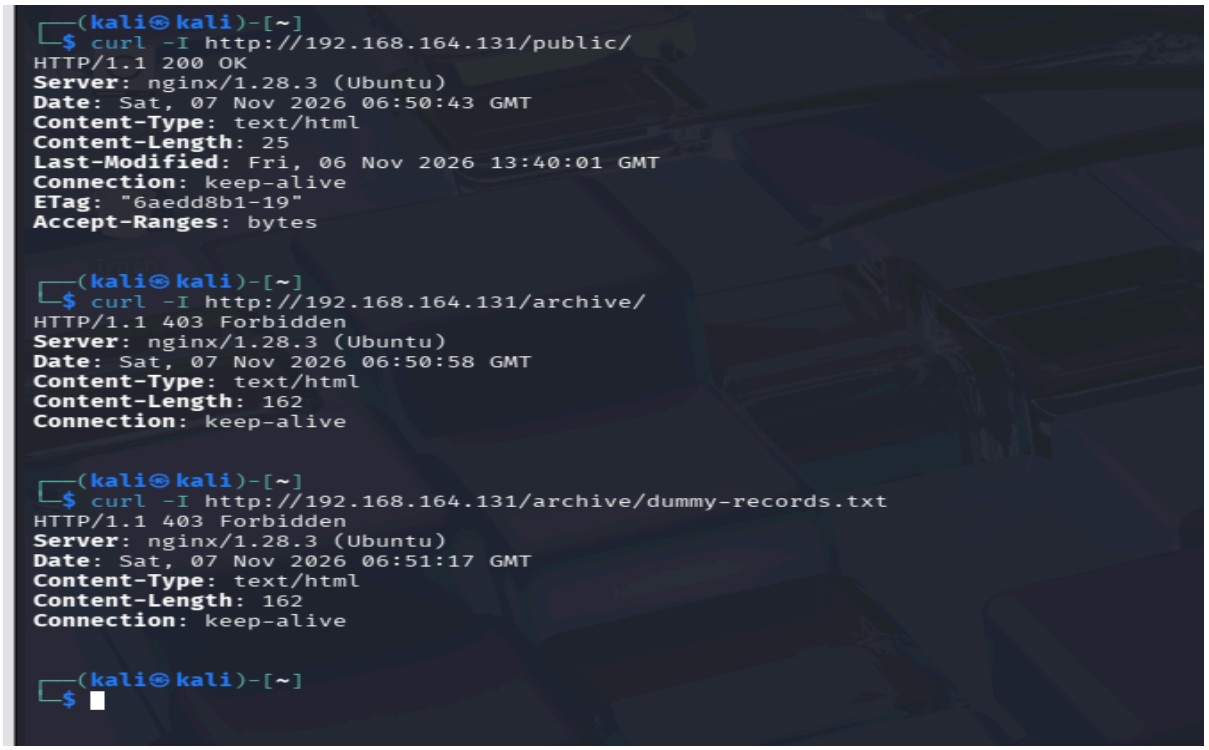


Figure 41. Ubuntu: archive still inside the web root before the move (ls -lah)

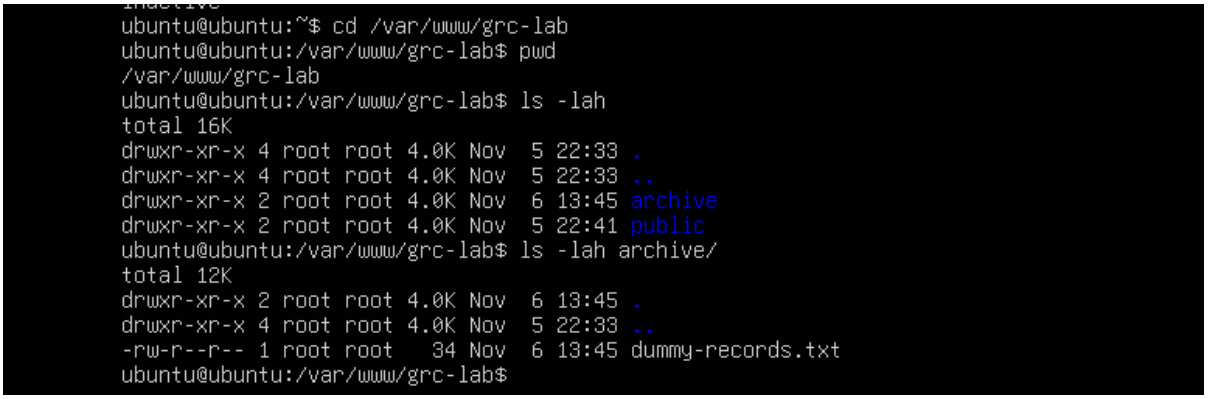



Figure 42. Ubuntu: archive moved to /srv/grc-private and restricted to root (permission denied for normal user)




Figure 43. Ubuntu (via SSH): Nginx server block with autoindex off and deny rule, nginx -t successful

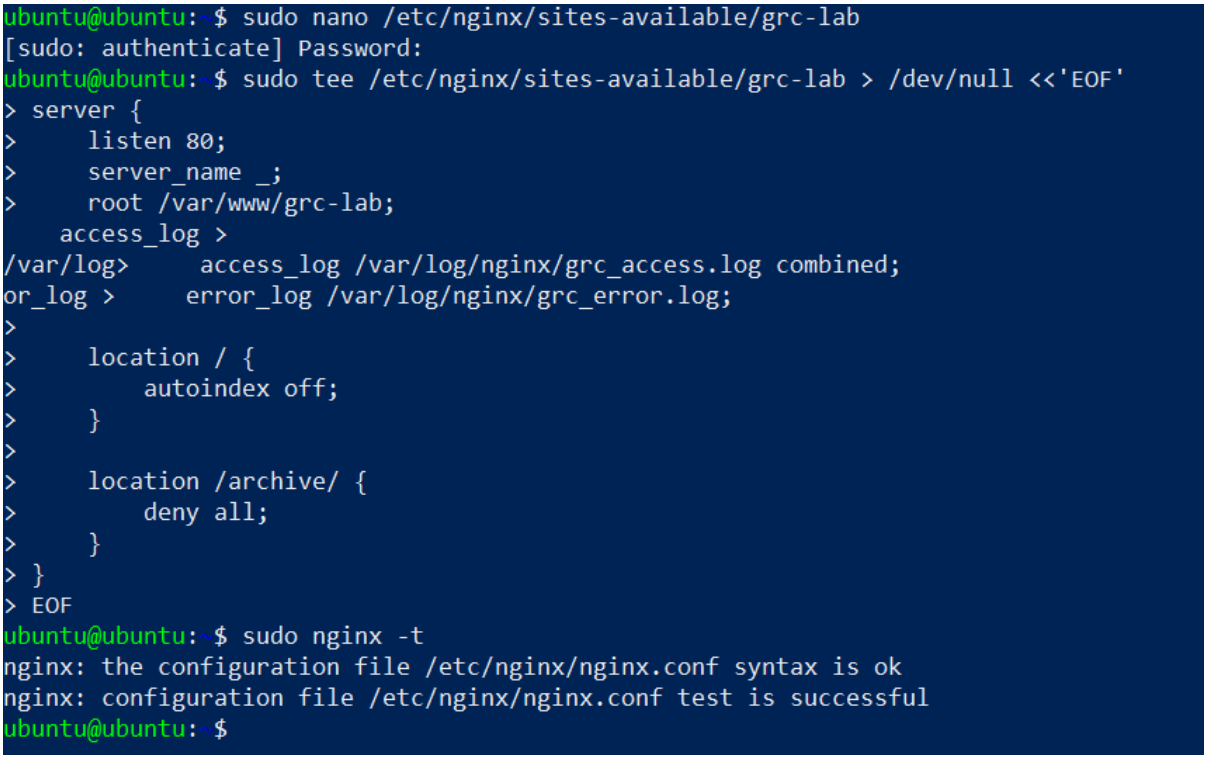



Figure 44. Ubuntu: Nginx reloaded

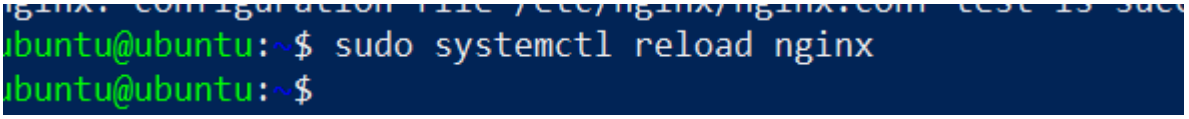


**Figure 45. Ubuntu console: ufw status (inactive), default policies, allow rule from 192.168.164.132 to port 80, logging on, ufw enabled**

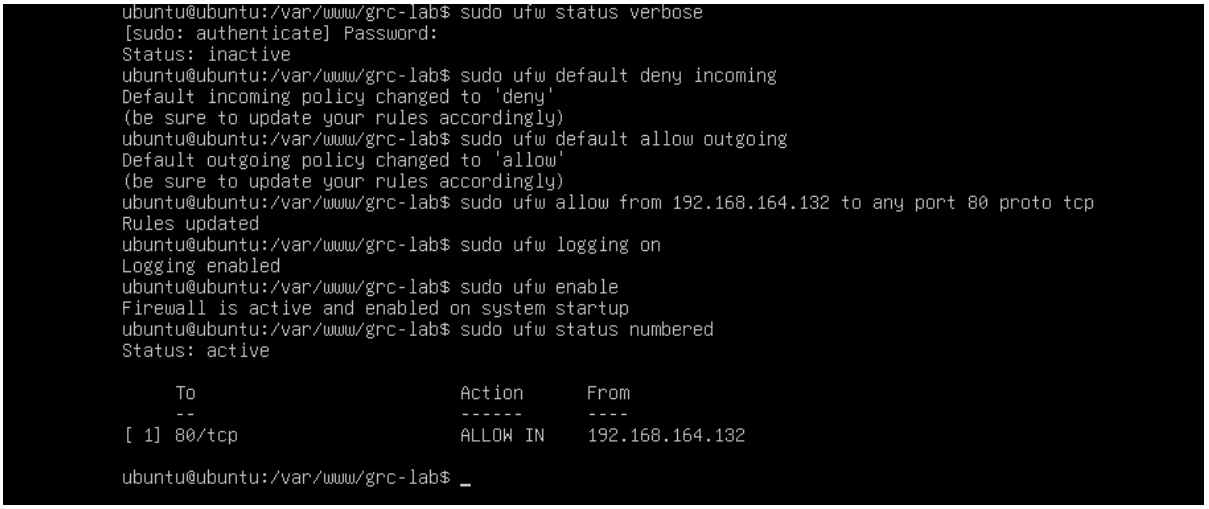



**Figure 46. Ubuntu: ufw status verbose after enabling**

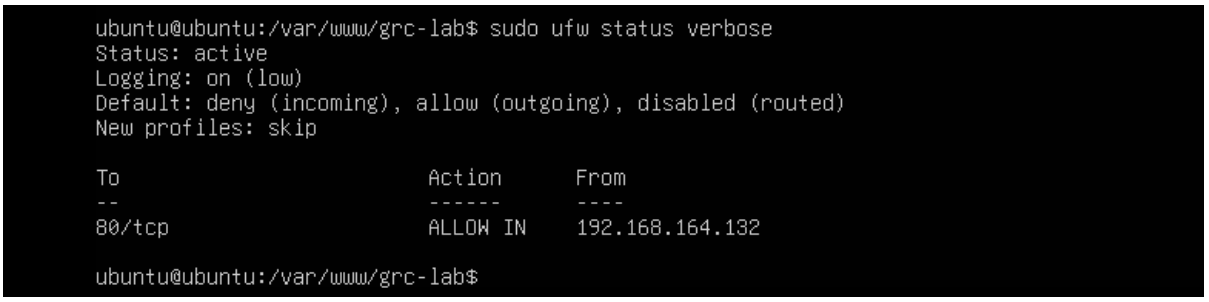



**Figure 47. Kali: tests after the firewall (/public/ 200, /archive/ 403) and Nmap -Pn on ports 22, 80, 8080**

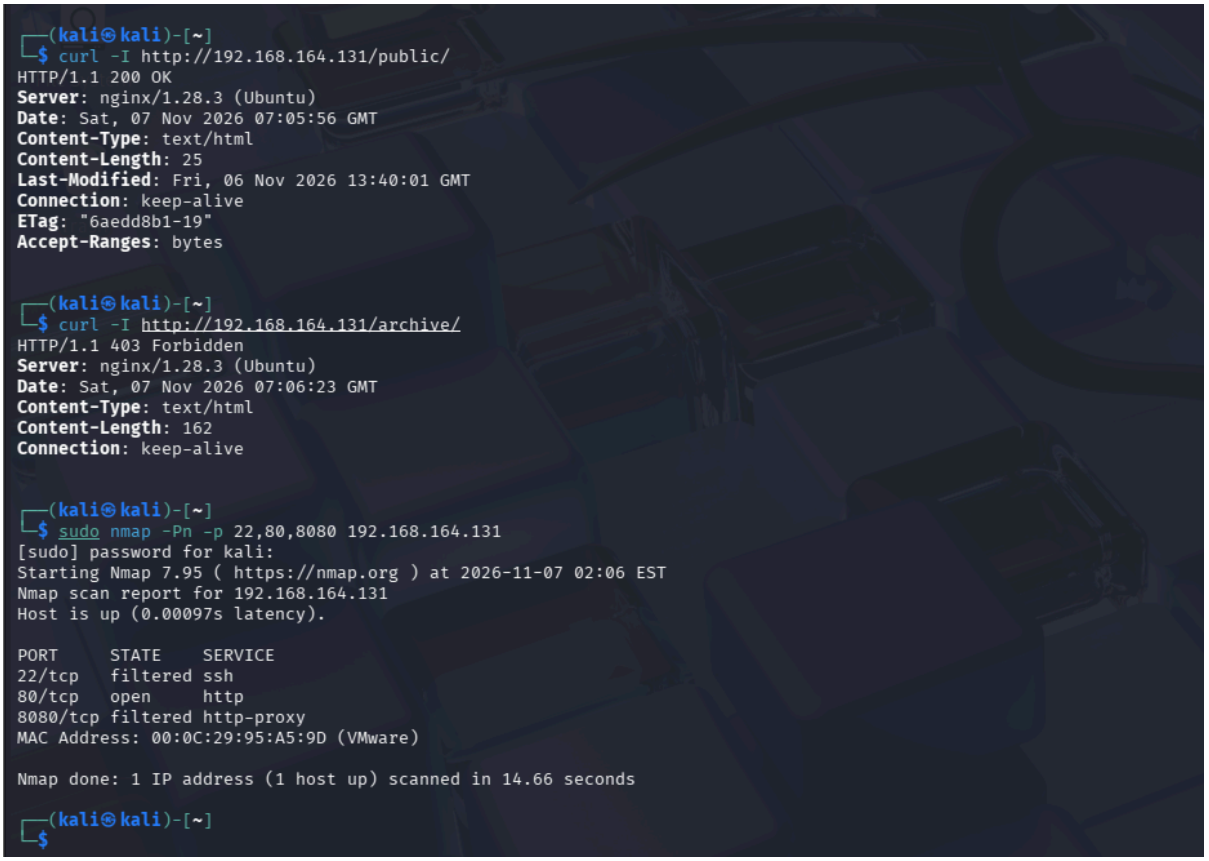


**Figure 48. Ubuntu: tail of the Nginx access log (grc_access.log)**




**Figure 49. Ubuntu: UFW BLOCK entries in /var/log/ufw.log**

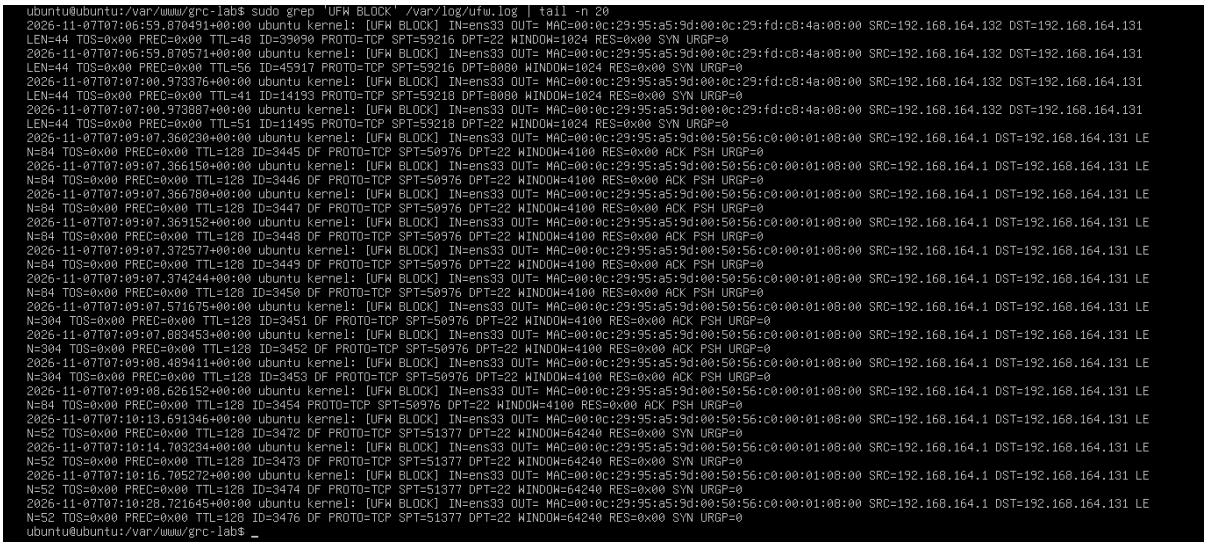



**Figure 50. Ubuntu: public directory listing, backup directory created, backup archive created**

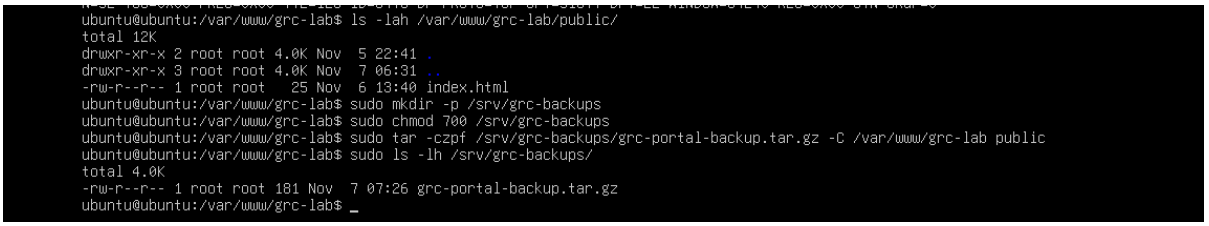



**Figure 51. Ubuntu: SHA-256 of index.html recorded and timestamp captured (07:38:26)**

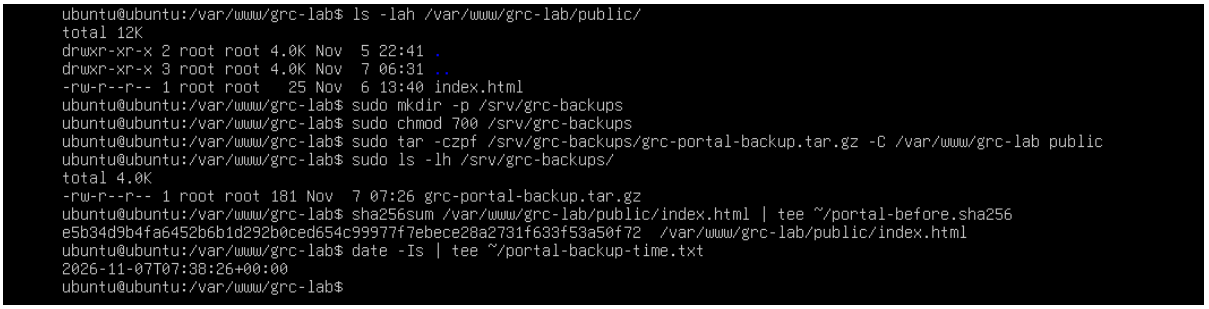



**Figure 52. Ubuntu: hash and timestamp saved into /srv/grc-backups (07:52:07)**



Figure 53. Ubuntu: index.html deleted, public directory empty

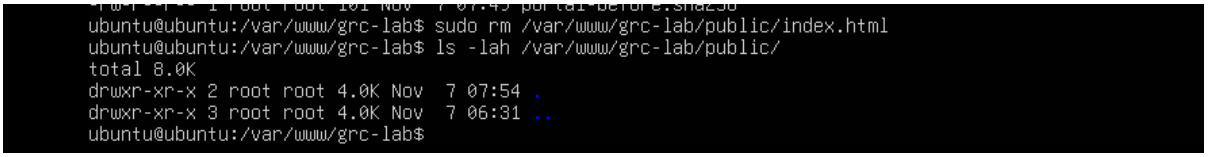



Figure 54. Kali: /public/ returns 403 after deletion (07:58:17 GMT)




Figure 55. Ubuntu: restore from backup with tar -xzpf, index.html back

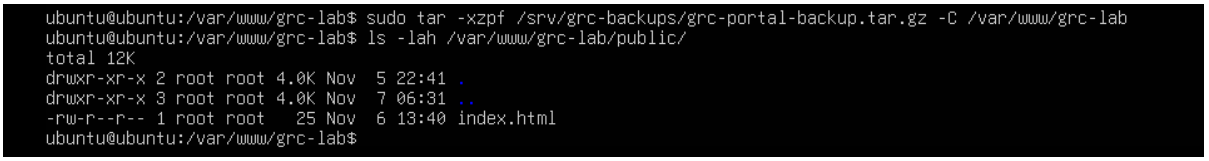



Figure 56. Ubuntu: sha256sum -c reports OK

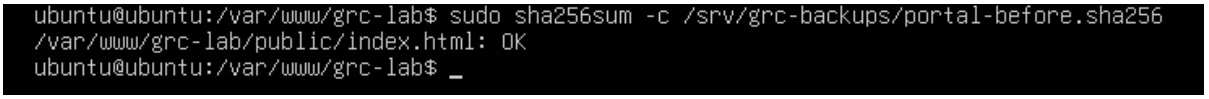



Figure 57. Kali: /public/ returns 200 after restore (08:05:25 GMT)

